



УНИВЕРЗИТЕТ У НОВОМ САДУ
ФАКУЛТЕТ ТЕХНИЧКИХ НАУКА У
НОВОМ САДУ



Огњен Стојисављевић

**Напредни систем контроле приступа у систему
паметне куће**

МАСТЕР РАД

Нови Сад, 2026.



УНИВЕРЗИТЕТ У НОВОМ САДУ • ФАКУЛТЕТ ТЕХНИЧКИХ НАУКА
21000 НОВИ САД, Трг Доситеја Обрадовића 6

КЉУЧНА ДОКУМЕНТАЦИЈСКА ИНФОРМАЦИЈА

Редни број, РБР:	
Идентификациони број, ИБР:	
Тип документације, ТД:	Монографска документација
Тип записа, ТЗ:	Текстуални штампани материјал
Врста рада, ВР:	Дипломски – мастер рад
Аутор, АУ:	Огњен Стојисављевић
Ментор, МН:	проф. др Марија Антић
Наслов рада, НР:	Напредни систем контроле приступа у систему паметне куће
Језик публикације, ЈП:	Српски / ћирилица
Језик извода, ЈИ:	Српски
Земља публикавања, ЗП:	Република Србија
Уже географско подручје, УГП:	Војводина
Година, ГО:	2026
Издавач, ИЗ:	Ауторски репринт
Место и адреса, МА:	Нови Сад; трг Доситеја Обрадовића 6
Физички опис рада, ФО: (поглавља/страна/ цитата/табела/слика/графика/прилога)	8/75/18/22/13/0/0
Научна област, НО:	Електротехника и рачунарство
Научна дисциплина, НД:	Рачунарска техника
Предметна одредница/Кључне речи, ПО:	ЈоТ, контрола приступа, корисничке подулоге, паметна кућа, OBLO, ACL, MQTT
УДК	
Чува се, ЧУ:	У библиотеци Факултета техничких наука, Нови Сад
Важна напомена, ВН:	
Извод, ИЗ:	Циљ рада је дизајн и реализација напредног система контроле приступа заснованог на корисничким подулогама у систему паметне куће, који отклања ограничења једнокорисничког модела. На основу прегледа литературе потврђена је потреба за вишекорисничким приступом у сценаријима попут изнајмљивања станова, апартмана, локала и пословне аутоматизације. Као основа је изабран OBLO систем паметне куће, проширен имплементацијом механизма подулога на свим слојевима система. Систем омогућава власнику да другим корисницима додели различите нивое приступа, ограничене по зонама и временски, уз ОТР верификацију. Систем је пројектован, реализован и тестиран према унапред задатим критеријумима, при чему резултати показују да их у потпуности испуњава.
Датум прихватања теме, ДП:	
Датум одбране, ДО:	
Чланови комисије, КО:	Председник: проф. др Иван Каштелан
	Члан: проф. др Иван Мезеи
	Члан, ментор: проф. др Марија Антић

Потпис ментора



UNIVERSITY OF NOVI SAD • FACULTY OF TECHNICAL SCIENCES
21000 NOVI SAD, Trg Dositeja Obradovića 6

KEY WORDS DOCUMENTATION

Accession number, ANO :	
Identification number, INO :	
Document type, DT :	Monographic publication
Type of record, TR :	Textual printed material
Contents code, CC :	Master Thesis
Author, AU :	Ognjen Stojisavljević
Mentor, MN :	Marija Antić PhD
Title, TI :	Advanced Access Control System in a Smart Home System
Language of text, LT :	Serbian
Language of abstract, LA :	Serbian
Country of publication, CP :	Republic of Serbia
Locality of publication, LP :	Vojvodina
Publication year, PY :	2026
Publisher, PB :	Author's reprint
Publication place, PP :	Novi Sad, Dositeja Obradovica sq. 6
Physical description, PD : (chapters/pages/ref./tables/pictures/graphs/appendixes)	8/75/18/22/13/0/0
Scientific field, SF :	Electrical Engineering
Scientific discipline, SD :	Computer Engineering, Engineering of Computer Based Systems
Subject/Key words, S/KW :	IoT, access control, user subroles, smart home, OBLO, ACL, MQTT
UC	
Holding data, HD :	The Library of Faculty of Technical Sciences, Novi Sad, Serbia
Note, N :	
Abstract, AB :	The aim of this thesis is the design and implementation of an advanced access control system based on user subroles in a smart home system, which overcomes the limitations of the single-user model. Based on a literature review, the need for multi-user access was confirmed in scenarios such as renting of houses, apartments, business premises, and commercial automation. The OBLO smart home system was chosen as the foundation, extended by implementing the subrole mechanism across all layers of the system. The system enables the owner to assign different access levels to other users, restricted by zones and time, with OTP verification. The system was designed, implemented, and tested according to predefined criteria, with results showing that it fully satisfies them.
Accepted by the Scientific Board on, ASB :	
Defended on, DE :	
Defended Board, DB :	President: Ivan Kaštelan, PhD
	Member: Ivan Mezei, PhD
	Member, Mentor: Marija Antić, PhD
	Mentor's sign



УНИВЕРЗИТЕТ У НОВОМ САДУ • ФАКУЛТЕТ ТЕХНИЧКИХ НАУКА
21000 НОВИ САД, Трг Доситеја Обрадовића 6

ИЗЈАВА О НЕПОСТОЈАЊУ СУКОБА ИНТЕРЕСА

Изјављујем да нисам у сукобу интереса у односу ментор – кандидат и да нисам члан породице (супружник или ванбрачни партнер, родитељ или усвојитељ, дете или усвојеник), повезано лице (крвни сродник ментора/кандидата у правој линији, односно у побочној линији закључно са другим степеном сродства, као ни физичко лице које се према другим основама и околностима може оправдано сматрати интересно повезаним са ментором или кандидатом), односно да нисам зависан/на од ментора/кандидата, да не постоје околности које би могле да утичу на моју непристрасност, нити да стичем било какве користи или погодности за себе или друго лице било позитивним или негативним исходом, као и да немам приватни интерес који утиче, може да утиче или изгледа као да утиче на однос ментор-кандидат.

У Новом Саду, дана _____

Ментор

Кандидат

	УНИВЕРЗИТЕТ У НОВОМ САДУ • ФАКУЛТЕТ ТЕХНИЧКИХ НАУКА 21000 НОВИ САД, Трг Доситеја Обрадовића 6	Број:
	ЗАДАТАК ЗА ЗАВРШНИ РАД	Датум:

Студијски програм:	Рачунарство и аутоматика		
Студент:	Огњен Стојисављевић	Број индекса:	E2 53/2023
Степен и врста студија:	Други степен, Мастер академске студије		
Област:	Рачунарска техника и рачунарске комуникације		
Ментор:	Марија Антић		
НА ОСНОВУ ПОДНЕТЕ ПРИЈАВЕ, ПРИЛОЖЕНЕ ДОКУМЕНТАЦИЈЕ И ОДРЕДБИ СТАТУТА ФАКУЛТЕТА ИЗДАЈЕ СЕ ЗАДАТАК ЗА ЗАВРШНИ РАД, СА СЛЕДЕЋИМ ЕЛЕМЕНТИМА: - проблем – тема рада; - начин решавања проблема и начин практичне провере резултата рада, ако је таква провера неопходна;			

НАСЛОВ ЗАВРШНОГ РАДА:

Напредни систем контроле приступа у систему паметне куће

ТЕКСТ ЗАДАТКА:

Циљ рада је дизајн и реализација напредног система контроле приступа заснованог на корисничким подулогама у систему паметне куће, који отклања ограничења једнокорисничког модела. На основу прегледа литературе потврђена је потреба за вишекорисничким приступом у сценаријима попут изнајмљивања станова, апартмана, локала и пословне аутоматизације. Као основа је изабран OBLO систем паметне куће, проширен имплементацијом механизма подулога на свим слојевима система. Систем омогућава власнику да другим корисницима додели различите нивое приступа, ограничене по зонама и временски, уз OTP верификацију. Систем је пројектован, реализован и тестиран према унапред задатим критеријумима, при чему резултати показују да их у потпуности испуњава.

Руководилац студијског програма:	Ментор рада:
Иван Каштелан	Марија Антић

Примерак за:

САДРЖАЈ

1. Увод.....	1
2. Теоријске основе	4
2.1 Интернет интелигентних уређаја и системи паметне куће	4
2.2 OBLO платформа за аутоматизацију паметне куће	5
2.3 Контролер.....	6
2.4 Сервис у облаку	7
2.5 Клијентске апликације	8
2.6 Периферни уређаји.....	9
2.7 Контрола приступа и улоге	9
2.8 Комуникација између компоненти система	13
3. Концепт решења.....	16
3.1 Анализа захтева	16
3.2 Кориснички профили и подулоге	18
3.3 Приступна права.....	20
3.4 Ограничење приступа по зонама	21
3.5 Временски ограничен приступ.....	24
3.6 Критеријуми решења	25
4. Архитектура система	27
4.1 Општа архитектура система.....	28
4.2 Улога сервиса у облаку.....	30
4.3 Улога контролера	32
4.4 Улога клијентских апликација	34
4.5 Синхронизација профила и ACL података	35
4.6 Токови комуникације између компоненти	37

5.	Програмско решење.....	39
5.1	Преглед и обим имплементације решења.....	40
5.2	Модел података за корисничке профиле и ACL	41
5.3	REST API команде за управљање профилима.....	44
5.4	MQTT комуникација и идентификација активног профила	48
5.5	Животни циклус корисничког профила.....	50
5.6	Синхронизација, догађаји и освежавање локалног стања.....	53
5.7	Извршавање команди и примена приступних права	56
6.	Тестирање система и резултати.....	60
6.1	План тестирања	60
6.2	Тестирање животног циклуса профила.....	62
6.3	Тестирање ограничења приступа по зонама и MQTT догађаја	63
6.4	Тестирање временски ограниченог приступа.....	65
6.5	Тестирање различитих нивоа права и провере на контролеру	67
6.6	Мерење времена одзива.....	69
6.7	Анализа резултата	70
7.	Закључак	71
8.	Литература.....	74

СПИСАК СЛИКА

Слика 2.1 – Архитектура OBLO система паметне куће	5
Слика 3.1 – Пример организације зона и уређаја у оквиру једне инсталације паметне куће	23
Слика 4.1 – Општа архитектура решења за корисничке подулоге у OBLO систему ..	29
Слика 4.2 – Токови комуникације између клијентске апликације, сервиса у облаку и контролера.....	37
Слика 5.1 – Пример ACL записа за приступ једној зони	43
Слика 5.2 – Логички садржај захтева за креирање корисничког профила.....	46
Слика 5.3 – Структура MQTT теме за захтеве ка контролеру у стандардном режиму и режиму са активном подулогом	48
Слика 5.4 – Усклађивање MQTT претплата са ACL листом активног профила	49
Слика 5.5 – Животни циклус корисничког профила	50
Слика 5.6 – Животни циклус инсталатерског приступа.....	52
Слика 6.1 – Креирање и преглед верификованих корисничких профила	63
Слика 6.2 – Усклађивање MQTT претплата са ACL листом активног профила	65
Слика 6.3 – Одбијање команде која није у складу са ACL правилима.....	68

СПИСАК ТАБЕЛА

Табела 2.1 – Поређење RBAC и ABAC модела контроле приступа	11
Табела 2.2 – Улога HTTP, REST и MQTT механизма у комуникацији између компоненти система паметне куће	14
Табела 3.1 – Корисничке подулоге у предложеном моделу контроле приступа	18
Табела 3.2 – Нивои приступних права у предложеном моделу	20
Табела 3.3 – Примена приступних права по корисничким подулогама	21
Табела 3.4 – Критеријуми предложеног решења	26
Табела 4.1 – Улоге сервиса у облаку у архитектури решења	31
Табела 4.2 – Улоге клијентских апликација у архитектури решења	35
Табела 4.3 – Основни кораци синхронизације профила и ACL података	36
Табела 5.1 – Основна поља модела UserProfileData	42
Табела 5.2 – Основна поља модела UserAccessControl	43
Табела 5.3 – REST API команде за управљање корисничким профилима	45
Табела 5.4 – Фазе животног циклуса корисничког профила	53
Табела 5.5 – Обрада догађаја који утичу на локално стање и приступни контекст	55
Табела 5.6 – Однос типа операције и потребног приступног права	57
Табела 5.7 – Логички ток примене приступних права приликом обраде захтева	58
Табела 6.1 – План тестирања механизма корисничких подулога	61
Табела 6.2 – Тестирање животног циклуса корисничког профила	62
Табела 6.3 – Тестирање ограничења приступа по зонама и MQTT догађаја	64
Табела 6.4 – Тестирање временски ограниченог приступа	66
Табела 6.5 – Тестирање различитих нивоа приступних права и провере на контролеру	68
Табела 6.6 – Упоредни приказ времена одзива у стандардном режиму и режиму са активном подулогом	69

СКРАЋЕНИЦЕ

IoT - енгл. Internet of Things — област која обухвата међусобно повезане уређаје способне да размењују податке и учествују у аутоматизованом управљању системом.

GW - енгл. Gateway — централни контролер система паметне куће.

SDK - енгл. Software Development Kit — скуп библиотека и алата који омогућавају развој апликација и интеграцију са системом.

API - енгл. Application Programming Interface — програмски интерфејс преко кога софтверске компоненте размењују податке и позивају функционалности.

REST - енгл. Representational State Transfer — архитектонски стил за пројектовање веб API сервиса.

HTTP - енгл. HyperText Transfer Protocol — протокол апликативног слоја заснован на моделу захтев/одговор.

MQTT - енгл. Message Queuing Telemetry Transport — протокол заснован на моделу објављивања и претплате (енгл. publish/subscribe), намењен размени порука у IoT системима.

RBAC - енгл. Role-Based Access Control — контрола приступа заснована на улогама.

ABAC - енгл. Attribute-Based Access Control — контрола приступа заснована на атрибутима субјекта, ресурса, операције и контекста.

ACL - енгл. Access Control List — листа контроле приступа која дефинише дозволе корисника над ресурсима.

OTP - енгл. One-Time Password — једнократна лозинка.

UI - енгл. User Interface — кориснички интерфејс.

UX - енгл. User Experience — корисничко искуство.

CRM - енгл. Customer Relationship Management — сервис у облаку који у оквиру OBLO система управља корисничким подацима и профилима.

UDM - енгл. User Device Management — сервис у облаку који управља везом између корисничких налога и контролера.

APIGTW - енгл. API Gateway — централна улазна тачка за API позиве ка сервисима у облаку.

OHM - енгл. OBLO Home Manager — компонента контролера задужена за функционалности паметне куће, уређаје, зоне, правила и догађаје.

OSM - енгл. OBLO System Manager — компонента контролера задужена за системске и административне функционалности.

BLE - енгл. Bluetooth Low Energy — бежични протокол мале потрошње.

IP - енгл. Internet Protocol — комуникациони протокол мрежног нивоа.

1. Увод

Интернет интелигентних уређаја (енгл. Internet of Things, IoT) представља област рачунарства у којој физички уређаји, сензори, актуатори и софтверске компоненте размењују податке и учествују у надзору и управљању окружењем [1], [2]. У домену паметне куће овај концепт се примењује на стамбене, пословне и угоститељске просторе, где корисник путем мобилне или веб апликације може да управља осветљењем, климатизацијом, безбедносним уређајима, ролетнама, сензорима и другим елементима система.

Систем паметне куће најчешће се састоји од периферних уређаја, локалног контролера, сервиса у облаку и клијентских апликација. Периферни уређаји мере или мењају стање физичког окружења, контролер извршава управљачку логику и комуницира са уређајима, сервиси у облаку омогућавају удаљени приступ и управљање подацима, док клијентске апликације представљају кориснички интерфејс (енгл. User Interface, UI) система.

Првобитни модели употребе паметне куће најчешће су подразумевали једног примарног корисника, односно власника система. Такав приступ је довољан за једноставне приватне инсталације, али постаје ограничен у сценаријима у којима исти систем користи више особа са различитим потребама и одговорностима [3], [4]. У једном домаћинству то могу бити чланови породице, станари и гости, у изнајмљеним становима привремени корисници, у хотелима гости и особље, а у пословним просторима запослени, администратори и сервисери.

Уколико сви корисници добију исти или превише широк ниво приступа, јавља се проблем прекомерних привилегија. Корисник коме је потребна само контрола уређаја у једној просторији не би требало да има могућност измене системске конфигурације, брисања уређаја, управљања осетљивим функцијама или доделе приступа другим особама.

Због тога систем паметне куће мора да омогући прецизније управљање приступом, у складу са улогом корисника, делом система који користи и трајањем приступа.

Мотив овог рада јесте дизајн и реализација механизма корисничких подулога (енгл. user subroles) у систему паметне куће. Подулога није глобална особина корисничког налога, већ улога коју тај налог има у контексту једне конкретне инсталације, односно једног контролера. Исти корисник може имати различит положај у различитим инсталацијама: у једној може бити власник, у другој станар, а у трећој гост. Због тога приступ не треба посматрати само на нивоу корисничког налога, већ у односу на конкретан контролер.

Решење је реализовано као проширење OBLO платформе за аутоматизацију паметне куће, која припада ширем контексту система за прикупљање података, интеграцију IoT уређаја и управљање паметном кућом [5]–[7]. У оквиру рада разматра се начин на који се постојећи систем проширује тако да подржи више типова корисничких профила, ограничење приступа по зонама, временски ограничен приступ и различите нивое овлашћења. Проширење није ограничено само на приказ у апликацији, већ обухвата сарадњу сервиса у облаку, контролера и клијентских апликација.

У оквиру решења приступ се организује кроз корисничке профиле који се дефинишу у контексту конкретног контролера. Такав приступ омогућава да се права корисника прилагоде стварној намени профила. Власник има пун приступ систему, док се приступ осталих корисника може ограничити на одређене зоне, функционалности или временски период.

Циљ рада је да прикаже процес увођења корисничких подулога у постојећи систем паметне куће. Рад обухвата анализу захтева, дефинисање концепта решења, опис архитектуре, програмску реализацију и тестирање функционалности. Практична провера обухвата креирање, верификацију, измену и брисање профила, ограничење приступа по зонама, временски ограничене профиле, различите нивое права и проверу усклађености система са дефинисаним критеријумима.

Рад је организован у следећа поглавља:

- Теоријске основе — приказ основних појмова везаних за IoT системе, архитектуру паметне куће, OBLO платформу, моделе контроле приступа, комуникационе механизме.
- Концепт решења — анализа захтева, дефинисање корисничких подулога, приступних права и критеријума које решење треба да испуни.
- Архитектура решења — приказ улога појединачних компоненти система и начина на који сервиси у облаку, контролер и клијентске апликације сарађују у спровођењу контроле приступа.

- Програмско решење — опис модела података, команди за управљање профилима, комуникације са контролером, животног циклуса профила, механизма синхронизације и примене приступних права.
- Тестирање и резултати — верификација функционалности, провера приступних права и анализа испуњености дефинисаних критеријума.
- Закључак — сумирање реализованог решења, резултата тестирања, ограничења и могућности даљег развоја.

2. Теоријске основе

У овом поглављу описани су појмови неопходни за разумевање предложеног решења. Обухваћени су основни појмови IoT система и система паметне куће, компоненте OBLO платформе, модели контроле приступа, као и комуникациони механизми који се користе између компоненти система.

2.1 Интернет интелигентних уређаја и системи паметне куће

IoT системи повезују физичке уређаје са софтверским сервисима и омогућавају да уређаји прикупљају податке, објављују информације о свом стању, примају команде и учествују у извршавању аутоматизованих правила [1], [2]. У систему паметне куће ови уређаји најчешће представљају сензоре и актуаторе. Сензори мере температуру, влажност, покрет, осветљеност или стање врата и прозора, док актуатори мењају стање окружења, на пример укључивањем светла, подешавањем температуре на термостату, подизањем ролетни или активирањем релеја.

Систем паметне куће мора да задовољи више захтева. Са једне стране, крајњем кориснику треба да понуди једноставан кориснички интерфејс и брз одзив. Са друге стране, систем мора да буде безбедан, поуздан и способан да ради и у условима нестабилне интернет везе [3], [4]. Због тога се логика често распоређује између локалног контролера и сервиса у облаку. Контролер обезбеђује локално управљање и комуникацију са уређајима, док сервис у облаку омогућава аутентификацију, удаљени приступ, складиштење података и централизовано управљање конфигурацијом.

У пракси се у системима паметне куће користи више комуникационих технологија и протокола. Контролер повезује различите периферне уређаје и сакрива детаље њихове комуникације од крајњег корисника. Због тога корисник не управља протоколима, већ логичким објектима система паметне куће, као што су зоне, уређаји, правила и стања.

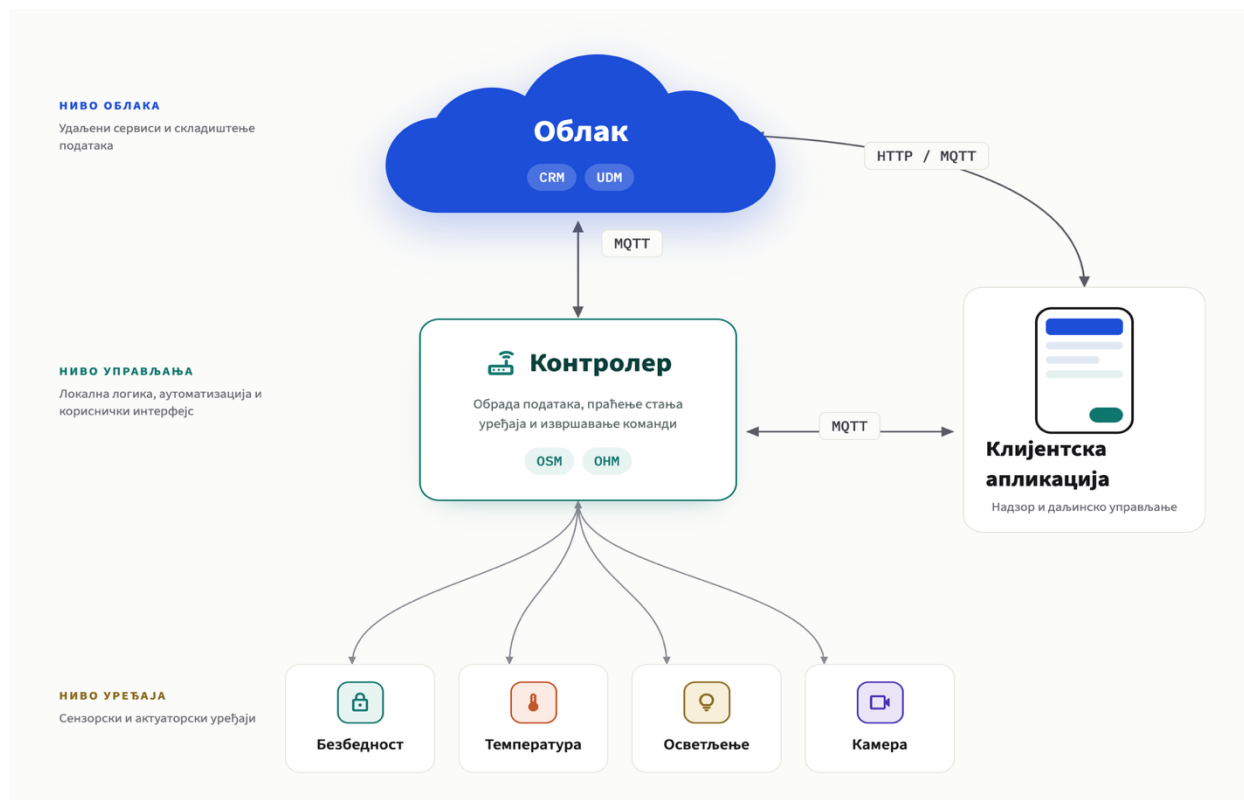
Конкретни комуникациони механизми који се користе између компоненти система описани су у потпоглављу 2.8.

2.2 OBLO платформа за аутоматизацију паметне куће

OBLO систем је платформа за аутоматизацију паметне куће заснована на дистрибуираној архитектури. Основне целине система су контролер, сервис у облаку, клијентске апликације и периферни уређаји. Оваква подела омогућава да контролер у локалној мрежи обрађује захтеве, комуницира са уређајима и одржава локални модел система, док сервис у облаку обезбеђује удаљени приступ, управљање корисничким налозима и централизовано чување података који су потребни за рад више корисника и инсталација.

Јавни радови који се односе на OBLO и сродна решења паметне куће разматрају прикупљање и анализу података, интеграцију са спољним IoT платформама и управљање системима паметне куће [5]–[7].

У типичном току рада корисник систему приступа путем мобилне или веб апликације. Апликација може да комуницира са контролером директно, када се корисник налази у локалној мрежи, или посредно преко сервиса у облаку, када је потребан удаљени приступ. У оба случаја контролер обрађује захтеве, комуницира са периферним уређајима и враћа податке о стању система клијентској апликацији.



Слика 2.1 – Архитектура OBLO система паметне куће

У контексту овог рада OBLO платформа посматра се као вишеслојни систем у коме контрола приступа мора бити усклађена између више компоненти. Сервис у облаку управља корисничким подацима и профилима, контролер представља централну компоненту за рад са локалним моделом система и периферним уређајима, док клијентске апликације приказују систем кориснику и омогућавају покретање дозвољених операција.

2.3 Контролер

Контролер (енгл. Gateway, GW) представља централну управљачку компоненту OBLO система паметне куће [5]–[7]. Физички се налази у простору корисника и повезан је са локалном мрежом и периферним уређајима, а у типичној инсталацији комуницира и са сервисом у облаку. Иако сервис у облаку омогућава удаљени приступ и централизовано управљање одређеним подацима, контролер представља језгро локалног рада система: одржава локални модел инсталације, прикупља податке са уређаја, обрађује захтеве, извршава команде и правила аутоматизације и враћа ажурно стање клијентској апликацији.

Контролер комуницира са различитим типовима периферних уређаја, као што су сензори и актуатори. Због хетерогености уређаја у систему паметне куће, контролер мора да подржи различите комуникационе технологије и протоколе, у зависности од конкретних уређаја и хардверске конфигурације система. На тај начин контролер има улогу слоја апстракције између физичких уређаја и клијентске апликације: корисник не мора да познаје конкретан протокол којим уређај комуницира, већ управља логичким објектима система као што су зоне, уређаји, правила и стања.

Клијентска апликација може да комуницира са контролером директно, када се корисник налази у локалној мрежи, или посредно преко сервиса у облаку, када је потребан удаљени приступ. У оба случаја контролер има кључну улогу у обради захтева, јер захтеве доводи у везу са локалним моделом система и уређајима којима управља. На тај начин исти контролер остаје централна тачка извршавања, без обзира на то да ли је захтев стигао локално или преко сервиса у облаку.

У контексту овог рада контролер је значајан зато што непосредно управља локалним моделом инсталације паметне куће. Тај модел обухвата зоне, уређаје, стања, правила и друге податке неопходне за рад система. Због тога се механизам корисничких подулога не може посматрати само као проширење сервиса у облаку или корисничког интерфејса, већ мора бити усклађен и са начином на који контролер обрађује захтеве и примењује правила над локалним ресурсима. Детаљнија улога контролера у архитектури решења описана је у поглављу 4, док је примена приступних права приликом извршавања команди описана у поглављу 5.

2.4 Сервис у облаку

Сервис у облаку представља серверски слој OBLO система који омогућава удаљени приступ, управљање корисничким налозима и централизовано чување података потребних за рад система паметне куће. У типичном начину рада он повезује клијентске апликације и контролер, омогућава приступ систему ван локалне мреже и обезбеђује инфраструктуру за рад са више корисника и више инсталација система паметне куће, при чему је свака инсталација везана за конкретан контролер. Јавни радови који се односе на OBLO и сродна решења паметне куће описују значај прикупљања података, интеграције IoT уређаја и управљања системима паметне куће [5]–[7].

Када се корисник налази ван локалне мреже у којој је контролер постављен, клијентска апликација не приступа контролеру директно, већ комуникација иде преко сервиса у облаку. Сервис у облаку прихвата захтев апликације, прослеђује га одговарајућем контролеру и враћа одговор апликацији. На тај начин корисник може да надзире стање система, извршава команде и приступа подацима независно од своје физичке локације, док контролер остаје компонента која непосредно ради са локалним моделом система и периферним уређајима.

У OBLO систему сервис у облаку није једна монолитна компонента, већ обухвата више специјализованих сервиса. За овај рад посебно су значајни CRM сервис (енгл. Customer Relationship Management), UDM сервис (енгл. User Device Management) и APIGTW сервис (енгл. API Gateway). CRM сервис управља корисничким подацима, профилима и правима приступа. UDM сервис управља везом између корисничких налога и контролера, односно омогућава да се за пријављеног корисника добије листа контролера којима има приступ. APIGTW сервис представља централну улазну тачку за API (енгл. Application Programming Interface) позиве клијентских апликација ка сервисима у облаку.

Са становишта корисничких подулога, сервис у облаку има значајну улогу јер представља место на коме се управља подацима о корисничким профилима и приступним правима. Профил се дефинише у односу на конкретан контролер, па исти кориснички налог може имати различите подулоге у различитим инсталацијама паметне куће. На основу података о типу профила, додељеним зонама, трајању приступа и нивоу дозвола могуће је ограничити приступ у складу са улогом коју корисник има у конкретној инсталацији.

Сервис у облаку је посебно значајан у сценаријима са више корисника, као што су изнајмљивање станова, хотелско окружење и пословни простори. У таквим случајевима потребно је раздвојити податке различитих корисника, контролера и организационих целина, како би сваки корисник приступао само подацима који припадају његовом контексту.

У контексту овог рада сервис у облаку не посматра се само као механизам за удаљени приступ, већ као компонента која омогућава централизовано управљање корисничким профилима и њихово повезивање са контролерима. Детаљнија расподела одговорности између сервиса у облаку, контролера и клијентских апликација описана је у поглављу 4, док је програмска реализација команди, синхронизације и примене приступних права описана у поглављу 5.

2.5 Клијентске апликације

Клијентске апликације представљају кориснички слој OBLO система. Њихова основна улога је да кориснику омогуће пријављивање на систем, избор контролера, надзор стања уређаја и извршавање дозвољених команди. Апликација приказује логички модел паметне куће, који обухвата зоне, уређаје, правила, паметне функције и подешавања система, без потребе да корисник познаје детаље комуникације са појединачним уређајима. Једноставан и разумљив кориснички интерфејс представља важан захтев система паметне куће, јер крајњи корисник најчешће управља хетерогеним скупом уређаја кроз јединствену апликацију [3], [4].

Клијентска апликација може бити реализована као мобилна апликација или као веб апликација доступна преко веб прегледача. У зависности од начина приступа, апликација може да комуницира са контролером директно, када се корисник налази у локалној мрежи, или посредно преко сервиса у облаку, када је потребан удаљени приступ. У оба случаја апликација формира корисничке захтеве, шаље их одговарајућој компоненти система и приказује добијене одговоре у облику разумљивом крајњем кориснику.

У контексту корисничких подулога, клијентска апликација приказује модел система у складу са активном улогом корисника. Поред тога, апликација прилагођава доступне опције и елементе корисничког интерфејса у складу са правима профила. На пример, корисник који нема право да управља конфигурацијом система не треба да види опције за измену системских подешавања, управљање контролером или управљање корисничким профилима.

Апликација може да омогући и управљање корисничким профилима, али само када су испуњени услови за рад механизма подулога и када активни корисник има одговарајућа права. Детаљан опис ових операција не припада теоријском опису клијентске апликације, већ програмском решењу, где се разматрају команде, модел података и животни циклус профила.

Иако клијентска апликација прилагођава приказ модела система и доступне опције активном профилу корисника, она не представља једини слој контроле приступа.

Ограничења у интерфејсу имају употребну улогу и спречавају корисника да покрене операције које нису у складу са његовим правима, али примена приступних права мора бити усклађена и са сервисом у облаку и са контролером.

2.6 Периферни уређаји

Периферни уређаји представљају физичке елементе система паметне куће са којима контролер комуницира. Њихова улога је да прикупљају податке из окружења или да извршавају команде којима се мења стање тог окружења. У OBLO систему периферни уређаји не комуницирају директно са корисничком апликацијом, већ преко контролера, који обрађује њихова стања, прослеђује команде и одржава локални модел система.

Према начину рада, периферни уређаји се најчешће деле на сензоре и актуаторе. Сензори мере или детектују вредности и догађаје у простору, као што су температура, влажност, покрет, осветљеност, отварање врата или прозора, присуство дима или детекција цурења воде. Актуатори, са друге стране, на основу примљене команде мењају стање физичког окружења. У ову групу спадају светла, ролетне, термостати, релеји, паметне утичнице, браве и други уређаји којима се може управљати.

Због различитих произвођача, намена и комуникационих технологија, периферни уређаји у систему паметне куће могу користити различите протоколе. Задатак контролера је да ове разлике сакрије од корисника и клијентске апликације. Корисник зато не управља протоколима и техничким детаљима уређаја, већ логичким објектима система, као што су уређаји, зоне, правила и стања.

Уређаји су у систему организовани у зоне, које представљају логичке или физичке целине једне инсталације паметне куће. Зона може бити просторија, спрат, апартман, канцеларија или друга целина у којој се налази један или више уређаја. Оваква организација олакшава кориснику преглед система, али има значај и за контролу приступа.

У контексту корисничких подулога, периферни уређаји представљају ресурсе којима се приступ ограничава у складу са правима корисника. Корисник не мора имати приступ свим уређајима у систему, већ само оним уређајима који припадају зонама које су му додељене. На тај начин гост, станар или други ограничени профил може да види и користи само део система који му је намењен, што омогућава примену подулога у приватним, изнајмљеним, хотелским и пословним просторима.

2.7 Контрола приступа и улоге

Контрола приступа представља механизам којим систем одређује ко има право да приступи одређеним ресурсима и које операције над тим ресурсима може да изврши. У

софтверским системима овај механизам је важан јер спречава неовлашћено читање података, измену конфигурације, извршавање недозвољених команди и доделу привилегија другим корисницима. У систему паметне куће контрола приступа има додатни значај, јер се софтверске одлуке могу директно одразити на физичко окружење.

Ресурс у систему паметне куће може бити уређај, зона, правило, подешавање система, кориснички профил или друга функционалност којом се управља преко апликације. Операције над ресурсима могу бити различите: преглед стања, извршавање команде, измена конфигурације, додавање или брисање објеката и управљање другим корисницима. Због тога није довољно само проверити да ли је корисник пријављен на систем, већ је потребно одредити шта тачно сме да види, покрене или измени.

Један од најраспрострањенијих модела контроле приступа је контрола приступа заснована на улогама (енгл. Role-Based Access Control, RBAC). У овом моделу дозволе се не додељују директно сваком кориснику појединачно, већ се дефинишу улоге које имају одређени скуп права. Кориснику се затим додељује једна или више улога, чиме добија права која припадају тим улогама. Овакав приступ поједностављује управљање дозволама, јер се права мењају на нивоу улоге, а не посебно за сваког корисника [8].

Контрола приступа заснована на атрибутима (енгл. Attribute-Based Access Control, ABAC) омогућава да се одлука о приступу донесе на основу више својстава. Та својства могу описивати корисника, ресурс, операцију или окружење у коме се захтев извршава. У систему паметне куће то значи да одлука о приступу може зависити од типа профила корисника, зоне којој уређај припада, врсте команде, времена трајања приступа или других параметара. Овакав приступ је флексибилнији од чистог RBAC модела, али је сложенији за имплементацију и одржавање [9].

У контексту паметне куће, класичан RBAC модел није увек довољан. Разлог је то што приступ не зависи само од улоге корисника, већ и од контекста у коме се захтев извршава. На пример, корисник може имати право да управља уређајима у једној зони, али не и у другој; гост може имати приступ само у одређеном временском периоду; инсталатер може имати проширена права, али само током ограниченог трајања сервисне интервенције. Због тога се у IoT системима често разматрају модели који комбинују улоге са додатним условима, као што су зона, тип ресурса, операција, време важења и стање корисничког профила [10]–[13].

Иако RBAC и ABAC представљају различите приступе контроли приступа, у пракси се они могу комбиновати. RBAC је погодан када систем има јасно дефинисане типове корисника и када се права могу груписати по улогама. ABAC је погоднији у ситуацијама у којима одлука о приступу зависи од додатног контекста, као што су својства ресурса, време,

локација или стање система. У систему паметне куће ова разлика је посебно значајна, јер није довољно знати само да ли је корисник власник, станар или гост, већ је потребно знати и којим зонама има приступ, колико дуго тај приступ важи и које операције сме да изврши.

Упоредни приказ RBAC и ABAC модела, са становишта начина доделе права, флексибилности и примене у систему паметне куће, дат је у Табели 2.1.

Карактеристика	RBAC	ABAC
Основни принцип	Приступ се одређује на основу улоге корисника.	Приступ се одређује на основу атрибута корисника, ресурса, операције и контекста.
Додела права	Права се додељују улогама, а корисници добијају улоге.	Права се израчунавају на основу правила и вредности атрибута.
Једноставност	Једноставнији за разумевање и администрацију.	Флексибилнији, али сложенији за имплементацију и одржавање.
Погодност за фиксне организације	Погодан када постоји стабилна хијерархија улога.	Мање погодан ако су правила једноставна и улоге довољне.
Погодност за динамична окружења	Ограничен када приступ зависи од контекста.	Погодан када приступ зависи од зоне, времена, типа ресурса или других услова.
Пример у паметној кући	Власник, станар, гост или инсталатер имају унапред дефинисан скуп права.	Гост има приступ само одређеној зони, само током одређеног периода и само за извршавање команди.
Недостатак	Може бити превише груб ако улога не описује довољно прецизно контекст приступа.	Може постати сложен ако постоји велики број атрибута и правила.

Табела 2.1 – Поређење RBAC и ABAC модела контроле приступа

Листа контроле приступа (енгл. Access Control List, ACL) представља практичан начин чувања дозвола над ресурсима. ACL дефинише који корисник или профил има одређени ниво приступа над конкретним ресурсом. У систему паметне куће ACL може да садржи информацију о томе да корисник има приступ одређеној зони, као и да ли тај приступ подразумева само преглед стања, извршавање команди или управљање конфигурацијом. На основу таквих података систем може да формира модел доступан активном профилу и да провери да ли је захтев у складу са додељеним правима.

У OBLO систему контрола приступа се посматра као механизам који захтева сарадњу више компоненти. Сервис у облаку управља корисничким профилима и приступним правима, клијентска апликација прилагођава приказ и доступне акције тренутном профилу корисника, док контролер учествује у примени правила приступа приликом обраде захтева. Оваква подела је важна јер кориснички интерфејс не сме бити једини механизам заштите. Приказ ограниченог модела система у апликацији побољшава корисничко искуство, али правила приступа морају бити усклађена и са компонентама које обрађују захтеве.

Корисничке подулоге у овом раду представљају проширење класичног појма улоге. Подулога је везана за конкретну инсталацију паметне куће, односно за конкретан контролер, а не за кориснички налог у целини. То значи да исти кориснички налог може имати различита права у различитим системима. На пример, један корисник може бити власник у свом стану, станар у другом простору и гост у хотелској соби. Због тога се приступна права морају посматрати у контексту конкретног контролера, додељених зона и трајања приступа.

Овакав приступ је повезан и са концептом вишезакупачке архитектуре (енгл. multitenancy), у којој више независних корисника, организационих целина или инсталација користи заједничку инфраструктуру, али са логички раздвојеним подацима и правима приступа. Иако клијентска апликација сакрива недоступне функционалности и на тај начин побољшава корисничко искуство (енгл. User Experience, UX), она не представља једини слој контроле приступа.

У оквиру предложеног решења приступ се не одређује само на основу типа корисника, већ и на основу контролера, додељених зона, нивоа дозвола и трајања приступа. Таква организација омогућава примену принципа најмањих привилегија, јер корисник добија само она права која су потребна за његову улогу и контекст употребе. На тај начин се смањује ризик од случајне или намерне злоупотребе, поједностављује управљање корисницима и омогућава безбедније коришћење система паметне куће у окружењима са више корисника.

2.8 Комуникација између компоненти система

Комуникација између компоненти система паметне куће заснива се на више протокола и архитектонских стилова. Пошто систем обухвата клијентске апликације, сервисе у облаку, контролер и периферне уређаје, није довољан један универзалан начин комуникације. Различити делови система имају различите захтеве у погледу брзине одзива, поузданости, начина адресирања, врсте података и типа операција које се извршавају.

Поред комуникације између апликације, сервиса у облаку и контролера, контролер комуницира и са периферним уређајима употребом различитих комуникационих технологија и протокола. У пракси се за ову намену могу користити ZigBee, Z-Wave, BLE (енгл. Bluetooth Low Energy) и IP комуникација (енгл. Internet Protocol). У овом раду ови протоколи нису предмет детаљне анализе, већ се посматрају као део слоја преко кога контролер повезује физичке уређаје са логичким моделом паметне куће.

REST (енгл. Representational State Transfer) представља архитектонски стил за пројектовање мрежних сервиса [14]. У REST приступу ресурси система се представљају преко јединствених адреса, а операције над њима се извршавају употребом стандардних HTTP метода. У контексту веб сервиса ови механизми се најчешће излажу кроз програмски интерфејс апликације. На пример, ресурс може представљати кориснички профил, контролер, листу уређаја или конфигурациони објекат, док клијентска апликација употребом API позива може да чита, креира, мења или брише податке.

У комуникацији између клијентских апликација и сервиса у облаку користи се HTTP протокол (енгл. HyperText Transfer Protocol). HTTP је протокол апликативног слоја заснован на моделу захтев/одговор, у коме клијент шаље захтев серверу, а сервер обрађује захтев и враћа одговор [15]. Овакав модел је погодан за операције у којима клијент иницира комуникацију, као што су пријављивање корисника, добијање листе контролера, читање конфигурације, креирање профила или измена података у сервису у облаку.

MQTT протокол (енгл. Message Queuing Telemetry Transport) представља лаган комуникациони протокол заснован на моделу објављивања и претплате (енгл. publish/subscribe) [16]. Уместо директне комуникације између пошиљаоца и примаоца, поруке се објављују на одређене теме, а заинтересоване компоненте се претплаћују на теме које желе да прате. Централну улогу у овом моделу има посредник, односно брокер, који прима поруке и прослеђује их претплаћеним странама. Овакав модел је погодан за IoT системе, јер омогућава ефикасну размену кратких порука и рад у окружењима са ограниченим ресурсима [16]–[18].

У систему паметне куће MQTT је посебно погодан за комуникацију која укључује контролер, стања уређаја, догађаје и команде. Контролер може да објављује промене стања

уређаја, док апликација или сервис у облаку могу да шаљу команде преко одговарајућих тема. На овај начин систем може брзо да преноси информације о променама стања, без потребе да клијент стално шаље упите серверу.

У локалном режиму рада клијентска апликација може директно да комуницира са контролером. У удаљеном режиму рада апликација комуницира са сервисом у облаку, који затим посредује у комуникацији са контролером. У таквом начину рада могу се комбиновати HTTP, REST и MQTT механизми: апликација шаље захтев сервису у облаку, сервис у облаку прослеђује поруку контролеру, а резултат се враћа апликацији.

У контексту контроле приступа, комуникациони механизми имају важну улогу јер сваки захтев мора бити повезан са корисничким профилем, контролером и ресурсом над којим се операција извршава. API позиви омогућавају управљање профилима и правима приступа на страни сервиса у облаку, док MQTT теме и поруке омогућавају пренос команди и догађаја ка контролеру и од контролера. Због тога структура комуникације мора бити усклађена са моделом приступних права.

Упоредни приказ HTTP и MQTT протокола и REST архитектонског стила, као и њихове улоге у комуникацији између клијентске апликације, сервиса у облаку и контролера, дат је у Табели 2.2.

Појам	Основна улога	Примена у систему
HTTP	Протокол заснован на моделу захтев/одговор.	Комуникација апликације са сервисима у облаку, пријављивање корисника, читање конфигурације и слање API захтева.
REST	Архитектонски стил за пројектовање веб API сервиса.	Организација ресурса и операција над њима, као што су читање, креирање, измена и брисање профила или других података.
MQTT	Протокол заснован на моделу објављивања и претплате.	Размена команди, догађаја и стања између апликације, сервиса у облаку и контролера.

Табела 2.2 – Улога HTTP, REST и MQTT механизма у комуникацији између компоненти система паметне куће

Комбинацијом ових приступа добија се систем који може да подржи удаљени приступ, локално управљање, синхронизацију стања и примену контроле приступа над конкретним захтевима. HTTP и REST су погодни за управљање ресурсима у сервисима у облаку, док MQTT омогућава ефикасну размену порука са контролером и брзо преношење промена стања у систему паметне куће.

3. Концепт решења

Након приказа основних компоненти OBLO система и теоријских основа контроле приступа, у овом поглављу дефинише се концепт решења за увођење корисничких подулога. Циљ овог дела рада није опис програмске имплементације, већ формулисање захтева, правила и ограничења која решење треба да испуни.

Предложени концепт полази од тога да приступ систему паметне куће мора бити одређен у контексту конкретног контролера, односно конкретне инсталације система. Због тога се у наставку поглавља анализирају типови корисничких подулога, нивои приступних права, ограничење приступа по зонама, временски ограничен приступ и критеријуми на основу којих се процењује исправност решења.

3.1 Анализа захтева

Увођење корисничких подулога у систем паметне куће захтева проширење постојећег модела приступа тако да подржи више корисника са различитим правима у оквиру исте инсталације. Основни захтев је да приступ не буде дефинисан само на нивоу корисничког налога, већ у односу на конкретан контролер. На тај начин исти кориснички налог може имати различиту улогу у различитим инсталацијама паметне куће.

Полазни проблем постојећег приступа је недовољна прецизност у сценаријима са више корисника. Ако корисник добије приступ целом систему, он може видети и користити зоне, уређаје и функционалности које нису неопходне за његову улогу. Због тога је потребно увести модел у коме се приступ одређује на основу типа профила, додељених зона, приступних права и, када је потребно, трајања приступа.

Решење мора да омогући дефинисање више типова корисничких профила, при чему сваки профил има јасно одређену намену и обим права. Корисник са најширим овлашћењима треба да може да управља приступом других корисника, док ограничени

корисници треба да имају приступ само деловима система који су им додељени. Овај захтев је посебно важан у сценаријима у којима исти систем користе власници, станари, гости, управници некретнина или инсталатери.

Поред поделе по типу профила, решење мора да подржи ограничење приступа по зонама и временски ограничен приступ. Ограничење по зонама омогућава да корисник види и користи само уређаје и функционалности које припадају додељеним деловима инсталације. Временско ограничење је значајно за привремене кориснике, као што су гости и инсталатери, јер њихов приступ треба да важи само током одређеног периода.

Решење мора да подржи основни животни циклус корисничког профила: креирање, верификацију, измену и брисање. Приликом креирања профила потребно је дефинисати кориснички налог коме се приступ додељује, контролер на који се профил односи, тип подулоге, додељене зоне и, када је потребно, трајање приступа. Измена профила треба да промени важећа правила приступа, док брисање профила мора да онемогући коришћење претходно додељених права.

Систем мора да обезбеди доследну примену приступних права на више нивоа. Модел система који се доставља кориснику треба да буде усклађен са активним профилем, тако да корисник добија само зоне, уређаје и функционалности које припадају његовом приступном контексту. Клијентска апликација затим приказује добијени модел и прилагођава доступне опције корисничког интерфејса у складу са правима профила. Међутим, ограничење приказа и доступних UI опција није довољно као једини механизам заштите. Због тога модел приступа мора бити усклађен и са извршним слојем система, како би се захтеви обрађивали у складу са профилем, додељеним зонама и приступним правима.

Поред функционалних захтева, решење треба да буде флексибилно, разумљиво крајњим корисницима и компатибилно са постојећим начином рада OBLO система. Уколико функционалност корисничких подулога није омогућена на страни сервиса у облаку или изабрани контролер не подржава обраду подулога, систем треба да настави да ради у стандардном режиму, без приказа додатних опција и без примене механизма подулога у комуникацији.

На основу ових захтева, предложено решење треба да омогући контролисано управљање приступом у систему паметне куће, уз подршку за различите типове корисника, ограничење по зонама, временски ограничен приступ, животни циклус профила и доследну примену приступних права. Ови захтеви представљају основу за дефинисање корисничких подулога, приступних права и критеријума решења у наставку поглавља.

3.2 Кориснички профили и подулоге

Кориснички профил представља везу између корисничког налога, контролера и подулоге коју тај корисник има у оквиру изабране инсталације паметне куће. За разлику од глобалне улоге корисничког налога, подулога се дефинише у односу на један контролер.

Власнички профил настаје када се недодељени контролер повеже са корисничким налогом. Корисник коме је контролер додељен постаје власник те инсталације и има најшири ниво овлашћења. Власник затим може да управља приступом других корисника, односно да креира, мења и брише корисничке профиле у оквиру тог контролера.

У предложеном моделу разликују се следеће корисничке подулоге: власник, управник некретнине, станар, гост и инсталатер. Свака подулога има различиту намену, обим одговорности и ограничења. Подулога одређује основни контекст приступа, док се конкретан обим приступа додатно одређује кроз ниво приступног права, додељене зоне и, код одређених профила, временско ограничење.

Сажет приказ корисничких подулога дат је у Табели 3.1.

Подулога	Начин настанка	Основна улога	Карактер приступа
Власник	Доделом недодељеног контролера корисничком налогу.	Примарни корисник инсталације.	Пун приступ систему и управљање профилима других корисника.
Управник	Додељује га власник.	Управљање корисничким профилима.	Може да управља профилима других корисника, али не и да уклони власника.
Станар	Додељује га власник или овлашћени корисник.	Коришћење система у додељеним зонама.	Има извршна права без временског ограничења и може да креира гостујући профил.
Гост	Додељује га овлашћени корисник.	Привремено коришћење система.	Има извршна права у додељеним зонама и временски ограничен приступ.
Инсталатер	Захтева приступ на основу серијског броја контролера, а овлашћени корисник одобрава захтев.	Подешавање, одржавање или сервисирање система.	Има проширена права током ограниченог периода, након чега се приступ уклања.

Табела 3.1 – Корисничке подулоге у предложеном моделу контроле приступа

Власник представља примарног корисника једне инсталације паметне куће. Он има пун приступ систему и управља корисничким профилима у оквиру свог контролера. Власник може да додељује приступ другим корисницима, мења постојеће профиле, додељује зоне и уклања кориснике из система.

Управник некретнине представља корисника коме власник додељује право управљања профилима других корисника. Ова подурога је намењена сценаријима у којима лице или организација управља приступом више корисника, на пример у изнајмљеним становима, апартманима или хотелском окружењу. Управник некретнине може да додаје, мења и уклања профиле као што су станар, гост и инсталатер, али не може да уклони власника контролера.

Станар представља корисника који користи систем у оквиру додељених зона. Он може да види стања уређаја и да извршава дозвољене команде, али нема право да управља целокупном конфигурацијом система. За разлику од госта, станар нема временско ограничење приступа. У оквиру дозвољених правила, станар може да креира гостујући профил.

Гост представља корисника са ограниченим и привременим приступом. Ова подурога се користи када је потребно омогућити приступ систему само током одређеног периода, као што су боравак у апартману, хотелској соби или привремено коришћење простора. Гост може да користи уређаје у зонама које су му додељене, али нема право да мења конфигурацију система, управља другим корисницима или приступа деловима инсталације који му нису додељени.

Инсталатер представља корисника коме је приступ потребан ради подешавања, одржавања или сервисирања система. За разлику од осталих профила, приступ инсталатера може започети захтевом који се односи на серијски број контролера. Након што овлашћени корисник одобри захтев, инсталатер добија проширена права потребна за техничку интервенцију. Овај приступ је временски ограничен.

Оваква подела подурога омогућава да се приступ систему дефинише у складу са стварном улогом корисника у конкретној инсталацији. Власник задржава пуну контролу над системом, управник некретнине може да преузме управљање корисничким профилима, станар и гост користе систем у дозвољеном обиму, док инсталатер добија привремена права потребна за сервисирање. Детаљније одређивање дозвољених операција врши се применом приступних права, која су описана у наредном потпоглављу.

3.3 Приступна права

Приступна права дефинишу које операције корисник сме да извршава над ресурсима система паметне куће. Док подулога описује улогу корисника у оквиру конкретне инсталације, приступно право одређује ниво операција које су дозвољене над одређеним ресурсом. Због тога подулога и приступно право нису исти појам, већ се међусобно допуњују.

У предложеном решењу користе се три нивоа приступних права: `read`, `execute` и `manage`. Право `read` представља основни ниво и омогућава преглед података и стања ресурса. Право `execute` подразумева могућности права `read` и додаје могућност извршавања команди. Право `manage` представља најшири ниво приступа и односи се на управљање ресурсима, конфигурацијом, профилима или другим административним функционалностима, у зависности од подулоге корисника и типа ресурса.

Сажет приказ нивоа приступних права дат је у Табели 3.2.

Право	Значење	Типична примена
read	Преглед стања и података без извршавања команди.	Приказ зона, уређаја и њихових тренутних стања.
execute	Извршавање дозвољених команди над ресурсима.	Управљање уређајима у додељеним зонама.
manage	Управљање конфигурацијом, профилима или ширим скупом функционалности, у складу са подулогом корисника.	Административне операције, управљање профилима и сервисне активности.

Табела 3.2 – Нивои приступних права у предложеном моделу

Приступна права се не посматрају изоловано, већ у комбинацији са подулогом корисника. Исто право може имати различит практични домет у зависности од типа профила коме је додељено. На пример, власник и инсталатер могу имати проширени ниво права, али власник има трајну контролу над својом инсталацијом, док инсталатер има временски ограничен приступ ради техничке интервенције. Слично томе, станар и гост могу имати право `execute`, али гост има временски ограничен приступ, док станар нема такво ограничење.

У Табели 3.3 приказана је веза између корисничких подулога и приступних права у предложеном моделу.

Подулога	Основно приступно право	Правила примене
Власник	manage	Има пуну контролу над инсталацијом, укључујући управљање корисничким профилима, зонама и конфигурацијом система.
Управник	read + управљање профилима	Управља профилима других корисника, али не може да уклони власника и нема улогу примарног корисника инсталације.
Станар	execute	Користи уређаје у додељеним зонама, нема временско ограничење и може да креира гостујући профил у оквиру дозвољених правила.
Гост	execute	Користи уређаје у додељеним зонама током ограниченог временског периода.
Инсталатер	manage	Има проширена права потребна за сервисирање, али само током одобреног временског периода.

Табела 3.3 – Примена приступних права по корисничким подулогама

Овакав приступ омогућава да се права не додељују сувише грубо. Тип подулоге одређује улогу корисника, приступно право одређује ниво дозвољених операција, а додатна правила одређују ограничења која произилазе из контекста. Због тога право manage не значи увек потпуно исту ствар за све профиле, нити право execute има исти домет код станара и госта.

Одлука о приступу зависи од комбинације више елемената: активне подулоге, приступног права, ресурса над којим се операција извршава, додељене зоне и трајања приступа. Корисник са правом execute може да управља уређајем само ако тај уређај припада зони која му је додељена. Корисник са временски ограниченим профилем може да користи систем само док је профил активан. На тај начин приступна права представљају један део ширег модела контроле приступа, који се допуњује ограничењем по зонама и временским ограничењем.

3.4 Ограничење приступа по зонама

Ограничење приступа по зонама представља један од кључних елемената предложеног модела контроле приступа. Док подулога одређује основну улогу корисника,

а приступно право дефинише тип операција које корисник сме да извршава, зона одређује просторни обим приступа. На тај начин се приступ не посматра само кроз питање шта корисник сме да уради, већ и над којим делом система то сме да уради.

Зона у систему паметне куће представља логичку или физичку целину једне инсталације. То може бити просторија, спрат, апартман, канцеларија или друга функционална целина у којој се налази један или више уређаја. Организација уређаја по зонама олакшава кориснику преглед система, али истовремено омогућава и прецизније управљање приступом.

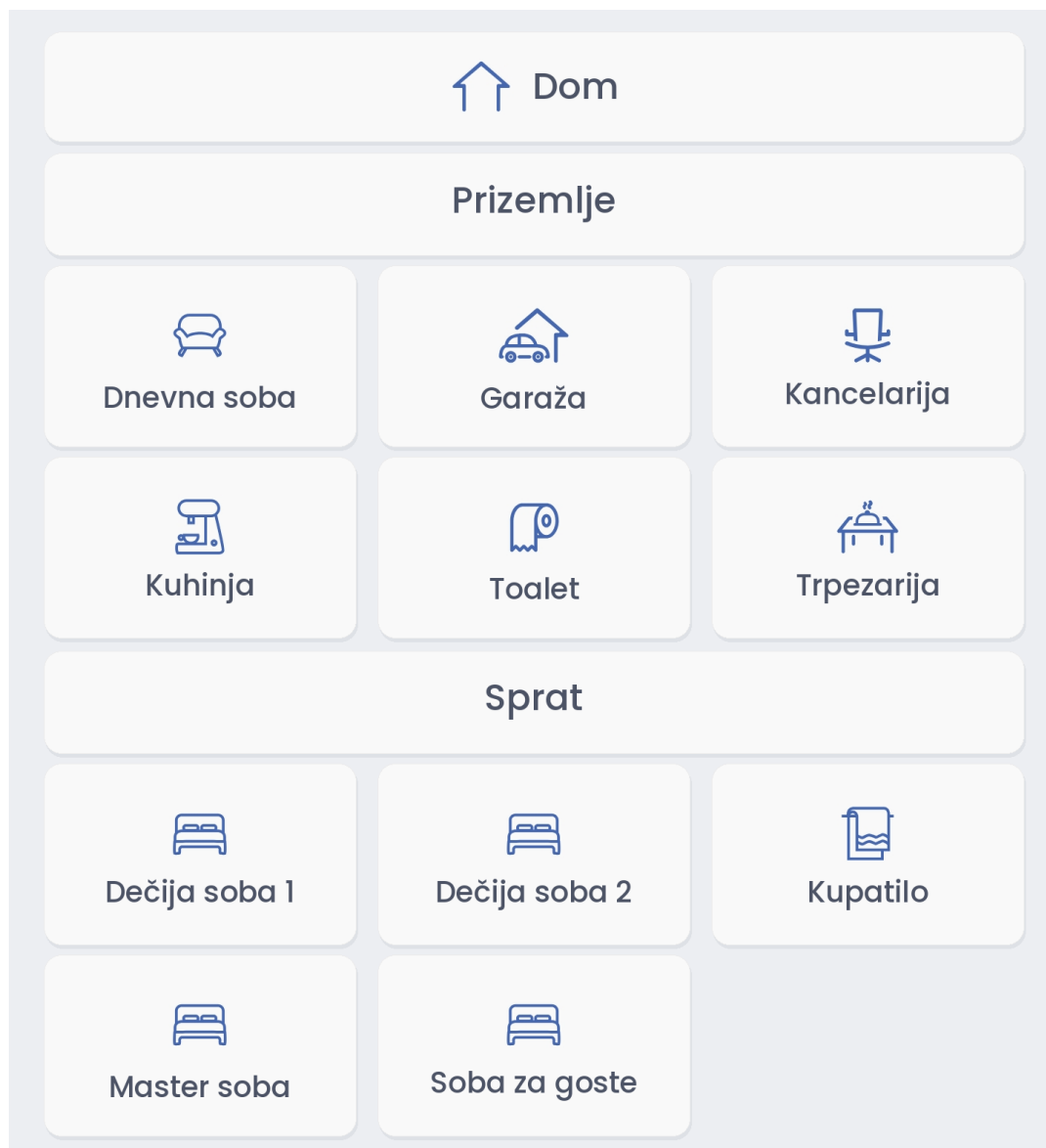
Логичка организација зона у оквиру једног контролера може обухватити главну зону, појединачне уређаје, зонске контролере и додатне зоне. Поједностављен пример такве структуре може се приказати на следећи начин:

- Номе зона
 - уређај 1
 - уређај 2
 - зонски контролер 1
 - Зона 1
 - уређај 3
 - уређај 4
 - зонски контролер 2
 - Зона 2
 - уређај 5
 - уређај 6

У приказаној структури контролер представља целокупну инсталацију паметне куће, док Номе зона представља главну зону у оквиру које се налази логичка организација система. Унутар Номе зоне могу се налазити појединачни уређаји, зонски контролери и додатне зоне које представљају мање логичке или физичке целине.

У предложеном решењу корисничком профилу могу бити додељене једна или више зона. Додељена зона не означава само приступ називу зоне, већ и приступ ресурсима који тој зони припадају. Ако је кориснику додељена одређена зона, он у апликацији види уређаје, зонске контролере и функционалности које су повезане са том зоном, у складу са својом подулогом и приступним правима.

Поред логичке структуре, ограничење приступа по зонама може се приказати и као просторна подела једне инсталације. Илустративан пример такве поделе приказан је на Слици 3.1.



Слика 3.1 – Пример организације зона и уређаја у оквиру једне инсталације паметне куће

У концептуалном смислу, зона представља ресурс над којим се примењују приступна права корисничког профила. То значи да се права `read`, `execute` и `manage` не тумаче независно од зоне, већ увек у односу на део система који је профили додељен. Корисник са правом `execute` може да управља уређајем само ако тај уређај припада зони која му је додељена. Исто важи и за право `read`, јер корисник треба да добије податке само о зонама и уређајима који су доступни његовом профили.

Ограничење по зонама посебно је важно у сценаријима у којима једна инсталација обухвата више логичких целина. У хотелском окружењу зона може представљати собу или

группу просторија које користи одређени гост. У пословном простору зона може представљати канцеларију, спрат или одељење. У изнајмљеним становима или апартманима зона омогућава да се приступ ограничи само на простор који је кориснику додељен.

Приликом рада са активном подулогом, модел система који се доставља клијентској апликацији треба да буде усклађен са зонама додељеним том профилу. То значи да корисник у апликацији не треба да види све зоне једне инсталације, већ само оне зоне које су му доступне. Са становишта корисника, остале зоне не представљају скривене елементе интерфејса, већ делове система који уопште не припадају његовом приступном контексту.

Ограничење по зонама зато не сме да се ослања само на приказ у апликацији. Клијентска апликација приказује податке које добија у контексту активног профила, али модел приступа мора бити усклађен и са обрадом захтева у извршном слоју система. На тај начин се спречава извршавање операција над ресурсима који не припадају дозвољеним зонама, без обзира на то да ли је захтев инициран кроз стандардни кориснички ток у апликацији или другим комуникационим путем.

Комбиновањем подулоге, приступног права и зоне добија се прецизнији модел управљања приступом. Подулога одређује улогу корисника у оквиру конкретне инсталације, приступно право одређује које операције су дозвољене, а зона одређује над којим делом система се те операције могу извршавати. Ова комбинација омогућава да се кориснику додели само онај обим приступа који је потребан за његову улогу, без непотребног приступа осталим деловима система.

3.5 Временски ограничен приступ

Временски ограничен приступ омогућава да кориснички профил важи само током одређеног периода. Овај механизам је значајан за кориснике којима је потребан привремен приступ систему, без трајног задржавања права након престанка потребе за коришћењем инсталације.

У предложеном решењу временско ограничење се примењује на госте и инсталатере. Гост добија приступ ради привременог коришћења простора, као што су апартман, хотелска соба или други изнајмљени простор. Инсталатер добија приступ ради подешавања, одржавања или сервисирања система. У оба случаја приступ треба да важи само током унапред дефинисаног периода.

Током активног периода профил омогућава приступ само ресурсима који су у складу са додељеним зонама и приступним правима. Након истека периода приступа, профил више не треба да омогућава преглед, управљање или извршавање команди над ресурсима

система. На тај начин временско ограничење допуњује подулогу, приступно право и ограничење по зонама.

Временско ограничење смањује потребу за ручним уклањањем привремених профила. Уколико би власник или овлашћени корисник морао ручно да уклања сваког госта или инсталатера након завршетка употребе, постојала би могућност да неки профил остане активан дуже него што је потребно. Аутоматско истекање приступа смањује тај ризик.

Примена временског ограничења мора бити доследна у систему. Сервис у облаку чува податке о трајању приступа и статусу профила, клијентска апликација ради са актуелним стањем профила, а извршни слој система мора да узме у обзир да ли је профил и даље активан. На тај начин време постаје додатни услов у одлуци о приступу, поред подулоге, приступног права и зоне.

3.6 Критеријуми решења

Критеријуми решења представљају основу за процену да ли предложени модел корисничких подулога испуњава захтеве дефинисане у претходним потпоглављима. Пошто се решење примењује у систему паметне куће који обухвата сервис у облаку, контролер и клијентске апликације, критеријуми морају да обухвате функционалне, безбедносне и употребне аспекте система.

Основни критеријуми односе се на то да приступ буде дефинисан у контексту конкретног контролера, да подулоге имају јасно раздвојене намене, да се приступна права примењују у комбинацији са зонама и временским ограничењем, као и да систем остане компатибилан са постојећим режимом рада. Посебно је важно да корисник добије модел система који одговара његовом активном профилу, а не целокупан модел инсталације са накнадно сакривеним елементима у апликацији.

Овако дефинисани критеријуми повезују концепт решења са његовом каснијом архитектуром, програмском реализацијом и тестирањем. У архитектури решења они одређују које компоненте система учествују у управљању приступом, у програмском решењу усмеравају модел података, комуникацију и синхронизацију, док у тестирању представљају основу за проверу да ли систем исправно примењује подулоге, приступна права, зоне и временска ограничења.

Сажет приказ критеријума предложеног решења дат је у Табели 3.4.

Критеријум	Опис
Контекст контролера	Подулога важи у односу на конкретан контролер, а не глобално за кориснички налог.
Раздвајање подулога	Сваки тип профила има јасно дефинисану намену и ограничења.
Приступна права	Систем примењује права read, execute и manage у складу са профилем, ресурсом и контекстом употребе.
Ограничење по зонама	Модел система који се доставља активном профилу ограничен је на зоне, уређаје, зонске контролере и функционалности које припадају том профилу.
Временско ограничење	Привремени профили важе само током дефинисаног периода.
Животни циклус профила	Подржано је креирање, верификација, измена и брисање профила.
Доследна примена права	Ограничења приступа морају бити усклађена са моделом који се приказује кориснику и са обрадом захтева у извршном слоју система.
Синхронизација података	Измене профила и права морају бити синхронизоване између компоненти система.
Употребљивост	Кориснички интерфејс треба да буде разумљив и да приказује опције које су у складу са активном подулогом.
Најмање привилегије	Корисник добија само приступ који је неопходан за његову улогу, додељене зоне и период важења профила.
Компатибилност са постојећим режимом	Систем наставља да функционише у стандардном режиму када функционалност корисничких подулога није омогућена или када је изабрани контролер не подржава.

Табела 3.4 – Критеријуми предложеног решења

Ови критеријуми представљају основу за даљу разраду архитектуре и програмске реализације решења. У наредним поглављима биће приказано како се наведени критеријуми остварују кроз сарадњу сервиса у облаку, контролера и клијентских апликација, као и како се њихова испуњеност проверава кроз тестирање корисничких профила, приступних права, зона и временских ограничења.

4. Архитектура система

Након дефинисања концепта корисничких подулога, приступних права, ограничења по зонама и временски ограниченог приступа, у овом поглављу описује се архитектура предложеног решења. Циљ поглавља је да прикаже како су компоненте OBLO система повезане у целину и на који начин сарађују у спровођењу контроле приступа.

Архитектура решења обухвата сервисе у облаку, контролер, клијентске апликације и ресурсе система организоване по зонама. Сервис у облаку има управљачку улогу, јер чува корисничке профиле, подулоге и приступна права. Контролер представља извршни слој, јер примењује добијена правила приликом обраде захтева над зонама, уређајима и другим ресурсима. Клијентске апликације омогућавају кориснику рад са системом и приказују модел и доступне опције у складу са активном подулогом.

Предложено решење није засновано на једном изолованом механизму, већ на сарадњи више компоненти. Када се профил креира, измени, верификује или обрише, промена мора бити забележена у сервису у облаку, синхронизована са контролером и одражена у приказу клијентске апликације. На тај начин све компоненте система раде са усклађеним подацима о приступу, без обзира на то да ли корисник систему приступа локално или удаљено.

Посебно је важно да контрола приступа не остане ограничена само на кориснички интерфејс. Клијентска апликација може да прилагоди приказ и сакрије недоступне функционалности, али одлука о томе да ли је конкретан захтев дозвољен мора бити усклађена и са извршним слојем система. Због тога архитектура решења раздваја управљање профилима, приказ доступних функционалности и проверу приступа приликом обраде захтева.

У наставку поглавља описују се општа архитектура система, улога сервиса у облаку, улога контролера, улога клијентских апликација, синхронизација профила и ACL података,

као и токови комуникације између компоненти система. Ови елементи представљају основу за разумевање програмске реализације која је описана у наредном поглављу.

4.1 Општа архитектура система

Општа архитектура предложеног решења заснива се на постојећој вишеслојној архитектури OBLO система, која обухвата сервисе у облаку, контролер, клијентске апликације и периферне уређаје. Увођењем корисничких подулога ова архитектура се проширује механизмима за управљање профилима, доделу приступних права, ограничење приступа по зонама и синхронизацију ACL података између сервиса у облаку и контролера.

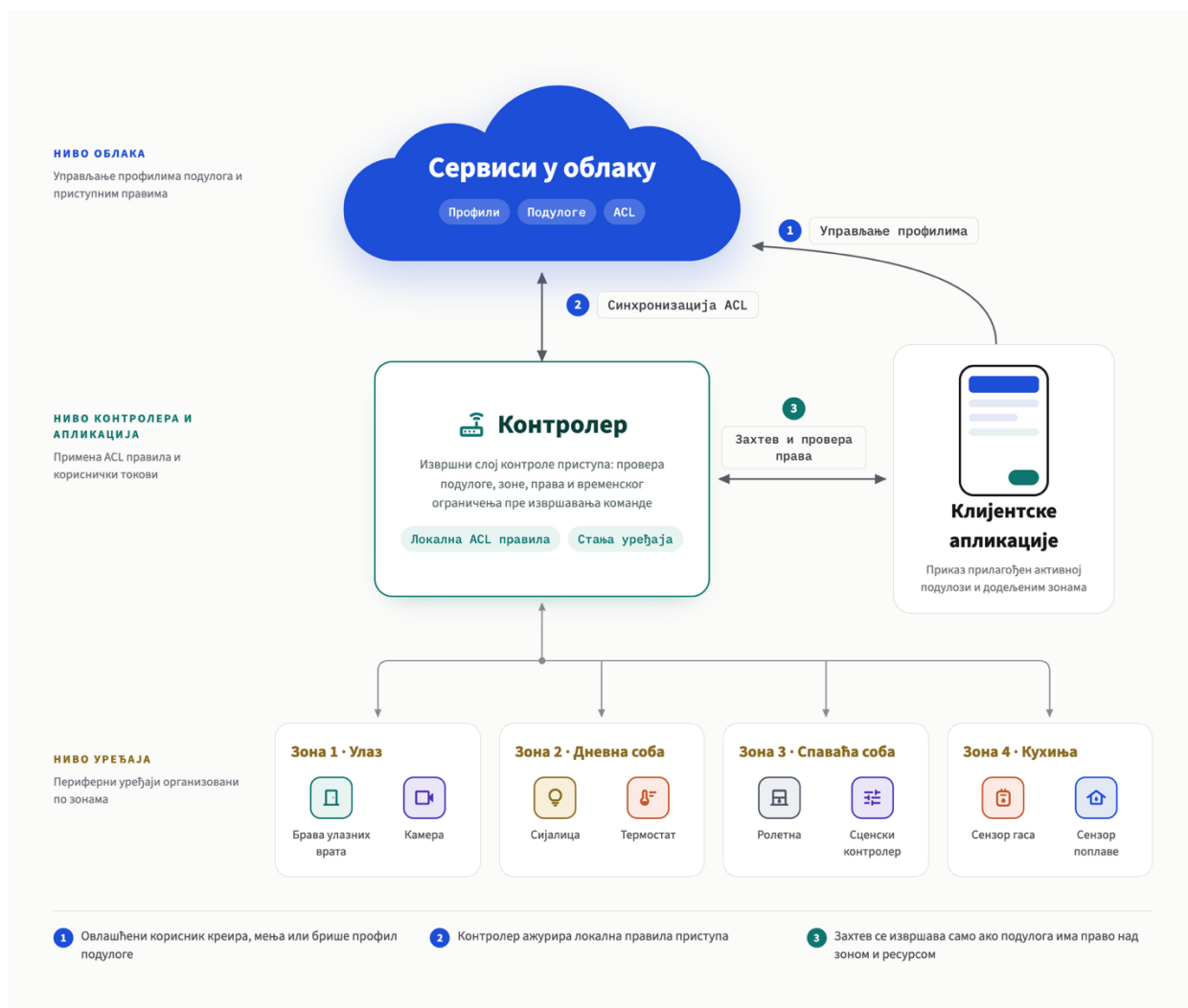
Предложена архитектура се надовезује на постојећи начин рада OBLO система. Када механизам корисничких подулога није активан, систем користи стандардне комуникационе токове и постојећу MQTT шему тема. Када је механизам активан, комуникација, модел ресурса који се доставља апликацији, приказ доступних опција и претплате на догађаје прилагођавају се активном профилу, додељеним зонама и ACL правилима.

У предложеном моделу сервис у облаку има управљачку улогу. У њему се креирају, мењају, верификују и бришу кориснички профили, као и подаци о типу подулоге, контролеру на који се профил односи, додељеним зонама, нивоу права и, код привремених профила, трајању приступа. Контролер има извршну улогу, јер на основу синхронизованих правила приступа обрађује захтеве који се односе на зоне, уређаје и друге ресурсе система. Клијентске апликације представљају кориснички слој који приказује модел система и доступне опције у складу са активним профилем.

Периферни уређаји представљају физичке ресурсе система паметне куће. Они су организовани у зоне, а приступ уређајима зависи од тога које зоне су додељене активном корисничком профилу. Кориснику који има приступ само једној зони доставља се модел који обухвата ресурсе који припадају тој зони, док се команде над уређајима извршавају преко контролера у складу са приступним правима.

Општа архитектура решења може се посматрати кроз три основна тока. Први ток је управљање профилима, у коме овлашћени корисник преко апликације креира, мења или брише профил, а сервис у облаку чува измене. Други ток је синхронизација профила и ACL података, у коме се контролер обавештава о променама и ажурира локална правила приступа. Трећи ток је извршавање корисничког захтева, у коме се захтев обрађује у складу са активном подулогом, приступним правом, зоном ресурса и актуелним статусом профила.

Општа архитектура предложеног решења приказана је на Слици 4.1.



Слика 4.1 – Општа архитектура решења за корисничке подулоге у OBLO систему

На Слици 4.1 приказана су три логичка нивоа решења: ниво облака, ниво контролера и клијентских апликација, као и ниво ресурса. Ниво облака обухвата управљање профилима, подулогама и ACL подацима. Контролер примењује локална ACL правила и проверава да ли активна подулога има право над траженом зоном или ресурсом. Клијентске апликације омогућавају управљање профилима и приказ система у складу са активном подулогом, док ниво ресурса обухвата зоне, уређаје и зонске контролере.

На слици су приказана и три основна тока: управљање профилима, синхронизација ACL података и обрада корисничког захтева. Управљање профилима иницира се из клијентске апликације и обрађује у сервисима у облаку. Синхронизацијом се ажурирају локална правила приступа на контролеру, док се приликом извршавања захтева користе подаци о активној подулози, приступном праву, зони којој ресурс припада и актуелном статусу профила.

Предложена архитектура је погодна за различите сценарије употребе паметне куће, као што су приватне инсталације, изнајмљени станови, апартмани, хотелско окружење и

пословни простори. У свим овим случајевима исти механизам омогућава да се кориснику додели подулога, ограниче зоне којима има приступ, одреди ниво дозвољених операција и, када је потребно, ограничи трајање приступа.

4.2 Улога сервиса у облаку

Сервис у облаку има управљачку и синхронизациону улогу у архитектури решења за корисничке подулоге. Његов задатак је да управља корисничким профилима, подацима о подулогама, приступним правима, додељеним зонама и временским ограничењима. За разлику од контролера, који примењује правила приступа приликом обраде конкретних захтева, сервис у облаку представља место на коме се та правила дефинишу, чувају и припремају за синхронизацију са осталим компонентама система.

Кориснички профил се у сервису у облаку чува као веза између корисничког налога и конкретног контролера. Такав приступ омогућава да исти кориснички налог има различиту подулогу у различитим инсталацијама паметне куће. Због тога сервис у облаку не води евиденцију само о кориснику, већ и о контролеру на који се профил односи.

У оквиру OBLO система за овај део решења посебно су значајни APIGTW, CRM и UDM сервиси. APIGTW представља улазну тачку за API позиве клијентских апликација. Клијентска апликација не комуницира директно са унутрашњим сервисима, већ своје захтеве шаље преко APIGTW слоја. На тај начин се захтеви централизовано прихватају, усмеравају ка одговарајућем сервису и обрађују у складу са правилима система.

CRM сервис је задужен за управљање корисничким профилима и приступним правима. У њему се креирају, мењају, верификују и бришу профили. Подаци који су значајни за профил обухватају кориснички налог коме се приступ додељује, контролер на који се профил односи, тип подулоге, додељене зоне, ниво приступног права, статус верификације и, код привремених профила, податак о трајању приступа. На основу ових података сервис у облаку управља животним циклусом профила и припрема правила која се синхронизују са контролером.

UDM сервис има улогу у повезивању корисничких налога са контролерима којима корисник има приступ. Када се корисник пријави у апликацију, систем мора да одреди којим контролерима тај корисник може да приступи и коју подулогу има у односу на сваки од њих. Због тога су подаци о профилу значајни приликом формирања листе контролера, јер апликација за изабрани контролер треба да ради у контексту одговарајуће подулоге.

Сервис у облаку управља и животним циклусом профила. Приликом креирања профила овлашћени корисник у апликацији бира тип подулоге, уноси податке о кориснику коме се приступ додељује и, у зависности од типа профила, додељује зоне и трајање

приступа. Након креирања, профил захтева верификацију пре него што постане активан. Измена профила омогућава промену подулоге, зона или трајања приступа, док брисање профила уклања право корисника да настави да користи претходно додељене ресурсе.

Код временски ограничених профила, као што су гост и инсталатер, сервис у облаку има улогу у управљању трајањем приступа. Када приступ истекне или профил буде уклоњен, промена се синхронизује са контролером и доставља клијентској апликацији. Ако апликација у том тренутку користи контролер на који се истекли или уклоњени профил односи, она треба да прекине активну везу са тим контролером и освежи доступне податке. На тај начин се спречава да корисник настави рад у контексту профила који више није важећи.

Подаци о приступним правима у сервису у облаку организују се кроз ACL податке. ACL описује над којим ресурсом кориснички профил има одређени ниво приступа. У контексту овог решења ресурс је најчешће зона, док приступно право може бити read, execute или manage. На овај начин сервис у облаку чува информацију не само о томе ко је корисник и коју подулогу има, већ и над којим зонама или ресурсима та подулога важи.

Након сваке промене профила или приступних права, сервис у облаку мора да обезбеди синхронизацију са контролером. Контролер мора имати ажурне ACL податке и актуелно стање профила како би могао да донесе исправну одлуку приликом обраде захтева. Због тога промена направљена у апликацији не сме остати само у сервису у облаку, већ мора бити прослеђена контролеру, који затим ажурира локална правила приступа.

Сажет приказ улога најзначајнијих сервиса у облаку дат је у Табели 4.1.

Компонента	Улога у решењу
APIGW	Представља улазну тачку за API позиве клијентских апликација и прослеђује захтеве одговарајућим сервисима.
CRM	Управља корисничким профилима, подулогама, приступним правима, верификацијом, трајањем приступа и ACL подацима.
UDM	Обезбеђује податке о контролерима којима корисник има приступ и профилима корисника у оквиру сваког контролера.
ACL подаци	Описују приступна права профила над зонама и другим ресурсима и користе се за синхронизацију правила приступа са контролером.

Табела 4.1 – Улоге сервиса у облаку у архитектури решења

Улога сервиса у облаку је, дакле, управљање профилима, приступним правима и њиховом синхронизацијом са контролером. Он дефинише и чува правила приступа, али не представља једини слој заштите. Провера захтева мора бити усклађена и са контролером,

јер се на том нивоу налазе локални модел система, зоне, уређаји и правила која одређују да ли се конкретна операција сме извршити. На тај начин сервис у облаку и контролер заједно обезбеђују доследну примену корисничких подулога у OBLO систему.

4.3 Улога контролера

Контролер представља извршни слој контроле приступа у предложеној архитектури решења. Док сервис у облаку управља корисничким профилима, подулогама, ACL подацима и животним циклусом профила, контролер је компонента која синхронизована правила примењује приликом обраде конкретних захтева. Због тога се контрола приступа не завршава на нивоу апликације или сервиса у облаку, већ мора бити усклађена и са компонентом на којој се захтев стварно примењује.

У OBLO систему контролер одржава локални модел инсталације паметне куће. Тај модел обухвата зоне, уређаје, стања уређаја, правила аутоматизације и друге функционалности потребне за рад система. У контексту корисничких подулога, контролер поред локалног модела система користи и синхронизоване податке о профилима и приступним правима. На основу тих података контролер може да формира одговоре у складу са активним профилем и да обради захтеве који се односе на зоне, уређаје и друге ресурсе система.

Када корисник пошаље захтев, контролер мора да утврди ком активном профилу тај захтев припада. Профил је одређен у контексту конкретног контролера, што омогућава да се права приступа примењују независно за сваку инсталацију. Приликом обраде захтева контролер користи податке о активном профилу, ACL правилима, зони којој ресурс припада, приступном праву и актуелном статусу профила. Ако су услови приступа испуњени, захтев се извршава или се враћа одговарајући податак. У супротном, захтев се одбија или се ресурс не укључује у одговор.

Посебно је значајна примена ограничења приступа по зонама. Уређаји и зонски контролери припадају одређеним зонама, па контролер мора да обрађује захтеве у складу са зонама које су додељене активном профилу. На пример, када апликација тражи модел зона и уређаја, контролер треба да врати модел који одговара активном профилу, односно само зоне и ресурсе који су том профилу доступни. Када корисник има право `execute` у једној зони, он може да извршава команде само над уређајима који припадају тој зони.

Контролер такође примењује разлику између нивоа приступних права. Право `read` омогућава приступ подацима и стањима, право `execute` омогућава извршавање команди, док право `manage` омогућава управљање конфигурацијом или административним функционалностима у складу са подулогом корисника и типом ресурса. Ова права се не

посматрају изоловано, већ у комбинацији са активним профилем, ACL подацима и ресурсом над којим се операција извршава.

У архитектури решења контролер мора да реагује на измене које настају у сервису у облаку. Када се профил креира, измени, верификује, обрише или када му се промене ACL подаци, контролер треба да ажурира локално доступна правила приступа. На тај начин се обезбеђује да одлуке о приступу буду засноване на актуелним подацима. Ово је посебно важно код временски ограничених профила, као што су гост и инсталатер, јер након истека или уклањања профила синхронизовано стање мора да спречи даљи рад у контексту тог профила.

У комуникационом смислу, контролер прима захтеве локално или преко сервиса у облаку. Када се корисник налази у локалној мрежи, клијентска апликација може директно комуницирати са контролером. Када је корисник ван локалне мреже, захтев се прослеђује преко сервиса у облаку. Без обзира на пут којим је захтев стигао, контролер треба да примени иста правила приступа. На тај начин се обезбеђује да локални и удаљени приступ буду доследно контролисани.

У оквиру контролера могу се издвојити функционалне целине које обрађују различите типове захтева. ОНМ (енгл. OBLO Home Manager) је задужен за функционалности паметне куће, као што су зоне, уређаји, правила и стања, док OSM (енгл. OBLO System Manager) обухвата системске и административне функционалности. Корисничке подулоге морају бити узете у обзир у оба случаја, јер приступ може бити ограничен и над уређајима и над системским операцијама. На пример, корисник може имати право да управља уређајима у својој зони, али не и право да мења системску конфигурацију контролера.

Оваква улога контролера спречава да се ограничење приступа ослања само на кориснички интерфејс. Клијентска апликација приказује модел система и доступне опције у складу са активним профилем, али то није довољно као једини механизам заштите. Корисник би теоретски могао да покуша да пошаље захтев који није понуђен кроз интерфејс. Због тога контролер мора да обради захтев у складу са синхронизованим ACL подацима, додељеним зонама и актуелним статусом профила.

Улога контролера у предложеној архитектури може се сажети као локална примена правила приступа. Сервис у облаку управља профилима и синхронизује правила, клијентска апликација прилагођава приказ кориснику, а контролер одлучује да ли се конкретан захтев сме извршити над конкретним ресурсом. На тај начин контролер представља кључну компоненту за безбедну и доследну примену корисничких подулога у OBLO систему.

4.4 Улога клијентских апликација

Клијентске апликације представљају кориснички слој предложене архитектуре. Њихова улога је да кориснику омогуће пријављивање на систем, избор контролера, приказ доступног модела система, извршавање дозвољених команди и управљање корисничким профилима када активна подулога има право за такве операције.

Након пријављивања корисника, апликација добија податке о контролерима којима корисник има приступ. За сваки контролер корисник може имати различиту подулогу, па се апликација након избора контролера понаша у складу са профилем који је активан за тај контролер. На тај начин исти кориснички налог може у једној инсталацији имати проширена права, а у другој ограничен приступ.

У контексту корисничких подулога, клијентска апликација приказује модел система који је добијен у складу са активним профилем. То значи да корисник не треба да види зоне, уређаје и зонске контролере који не припадају његовом приступном контексту. Поред тога, апликација прилагођава доступне елементе корисничког интерфејса типу профила и приступним правима. На пример, управник може имати приказ опција за управљање корисничким профилима, али не и опције за директно управљање уређајима. Станар може имати могућност коришћења уређаја у додељеним зонама и креирања дозвољених гостујућих профила, док гост нема приступ управљању профилима или системским подешавањима.

Апликација има важну улогу и у спречавању покретања недозвољених корисничких токова. Кориснику се не приказују опције за операције које нису у складу са његовом подулогом, па он у стандардном корисничком току нема могућност да формира захтев за радњу за коју нема овлашћење. Ипак, ово ограничење приказа није довољно као безбедносни механизам, јер проверу захтева морају да спроведу и компоненте које обрађују податке и извршавају команде.

Клијентска апликација учествује и у синхронизацији стања са сервисом у облаку и контролером. За операције над корисничким профилима, као што су креирање, измена, верификација и брисање, апликација шаље API захтеве сервисима у облаку. За рад са системом паметне куће апликација комуницира са контролером директно у локалној мрежи или посредно преко сервиса у облаку када је корисник удаљен. При томе апликација мора да освежава податке о активном профилу, доступним зонама, уређајима и функционалностима.

Посебан део улоге клијентске апликације односи се на пријем догађаја. Када активни профил има приступ само одређеним зонама, апликација треба да прати догађаје и промене стања који се односе на те зоне. Претплате на MQTT теме и обрада догађаја зато морају

бити усклађене са зонама и правима активног профила. Ако се профил измени, истекне или буде уклоњен, апликација треба да освежи приказ, усклади активне претплате и, ако је потребно, прекине активну везу са контролером који више није доступан у датом профилу.

Сажет приказ улога клијентске апликације у предложеној архитектури дат је у Табели 4.2.

Улога апликације	Опис
Пријава и избор контролера	Омогућава кориснику приступ систему и избор контролера у чијем контексту се активира одговарајући профил.
Приказ према подулози	Приказује добијени модел система и доступне UI опције у складу са активним профилем, додељеним зонама и приступним правима.
Управљање профилима	Омогућава креирање, измену, верификацију и брисање профила када активна подулога има право за такве операције.
Претплата на догађаје зона	На основу ACL података активног профила, апликација се претплаћује на MQTT теме за додељене зоне и прима релевантне догађаје и промене стања.
Комуникација са облаком и контролером	Шаље API захтеве сервисима у облаку и размењује податке са контролером локално или удаљено.

Табела 4.2 – Улоге клијентских апликација у архитектури решења

Улога клијентске апликације је да кориснику прикаже исправан и прилагођен интерфејс, омогући покретање дозвољених токова и одржава локални приказ у складу са подацима добијеним од сервиса у облаку и контролера. Она не представља завршни слој контроле приступа, већ део архитектуре који повезује корисничке акције са сервисима у облаку и контролером. Безбедносна исправност решења постиже се тек сарадњом ова три слоја.

4.5 Синхронизација профила и ACL података

Синхронизација профила и ACL података повезује управљачки део решења, који се налази у сервису у облаку, са извршним делом који се налази на контролеру и приказним делом у клијентској апликацији. Њена улога је да све компоненте система користе усклађене податке о активним профилима, додељеним зонама и приступним правима.

Сервис у облаку представља ауторитативни извор података о корисничким профилима. У њему се чувају подаци о корисничком налогу, контролеру на који се профил

односи, типу подулоге, статусу верификације, додељеним зонама, нивоу приступа и, код привремених профила, трајању приступа. Контролер не креира ова правила самостално, већ их добија ажурирањем из сервиса у облаку и користи приликом обраде захтева над ресурсима система.

Промене које утичу на права приступа пропагирају се кроз систем путем одговарајућих догађаја и обавештења. То обухвата креирање, измену, верификацију или брисање профила, промену ACL података, одобравање или одбијање инсталатерског приступа и истек временски ограниченог профила. Након пријема таквог догађаја, контролер освежава локално доступна правила приступа, док клијентска апликација освежава активни профил, доступан модел система и функционалности које треба да буду приказане кориснику.

Сажет приказ основних корака синхронизације дат је у Табели 4.3.

Корак	Опис
Промена профила	Кориснички профил се креира, мења, верификује, брише или му се мењају ACL подаци.
Обрада у облаку	Сервис у облаку ажурира податке о профилу, подулози, зонама, правима и статусу профила.
Реакција контролера на догађај	Контролер добија обавештење о промени профила или ACL података и освежава локална правила приступа.
Реакција апликације на догађај	Апликација освежава активни профил, доступан модел система, приказане функционалности и, по потреби, активну везу са контролером.
Усклађивање комуникације	MQTT претплате и пријем догађаја усклађују се са зонама које су доступне активном профилу.

Табела 4.3 – Основни кораци синхронизације профила и ACL података

Синхронизација утиче и на комуникацију у реалном времену. Када је активан профил са ограниченим приступом, апликација се на основу ACL података претплаћује на MQTT теме за додељене зоне. На тај начин прима догађаје и промене стања само за ресурсе који су доступни активном профилу. После измене ACL података апликација треба да ажурира MQTT претплате у складу са зонама које су додељене активном профилу, како не би наставила да прима догађаје за зоне којима профил више нема приступ.

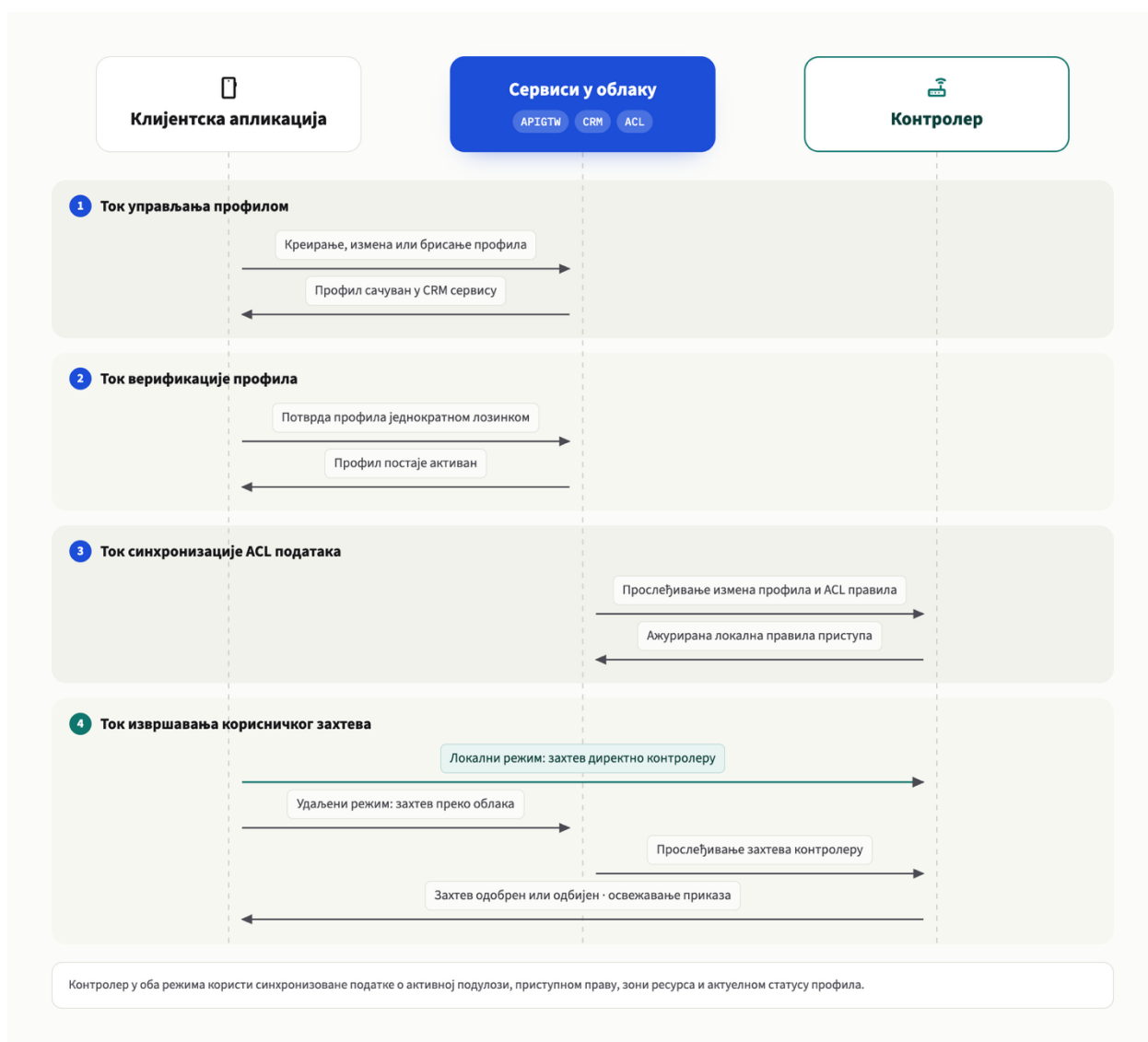
Код временски ограничених профила, као што су гост и инсталатер, сервис у облаку управља трајањем приступа. Када приступ истекне или профил буде уклоњен, промена се пропагира ка контролеру и клијентској апликацији. Ако апликација у том тренутку користи

контролер на који се истекли или уклоњени профил односи, она треба да прекине активну везу са тим контролером и освежи доступне податке.

На овај начин синхронизација обезбеђује да се промена направљена у сервису у облаку одрази и на контролер и на клијентску апликацију. Контролер користи ажурирана правила приликом обраде захтева, док апликација приказује и прати само оне ресурсе који су у складу са активним профилем, додељеним зонама и приступним правима.

4.6 Токови комуникације између компоненти

Токови комуникације између компоненти система описују начин на који клијентска апликација, сервиси у облаку и контролер сарађују приликом управљања корисничким профилима, пропагације измена и извршавања корисничких захтева. Комуникациони токови предложеног решења приказани су на Слици 4.2.



Слика 4.2 – Токови комуникације између клијентске апликације, сервиса у облаку и контролера

Управљање профилима одвија се између клијентске апликације и сервиса у облаку. Овлашћени корисник у апликацији покреће креирање, измену или брисање профила, а захтев се преко API слоја прослеђује сервисима у облаку. Подаци о профилу чувају се у CRM сервису, где се воде информације о кориснику, контролеру, типу подулоге, додељеним зонама, приступним правима и трајању приступа када је оно применљиво. Код профила који захтевају потврду, приступ постаје активан тек након верификације.

Измене профила и ACL података пропагирају се ка контролеру путем одговарајућих догађаја и обавештења. Контролер након тога освежава локално доступна правила приступа, док клијентска апликација освежава доступан модел система, приказане функционалности и, када је потребно, MQTT претплате за додељене зоне. На тај начин промена направљена у сервису у облаку постаје видљива и у извршном слоју и у корисничком приказу.

При извршавању корисничког захтева апликација може комуницирати са контролером директно, када се корисник налази у локалној мрежи, или посредно преко сервиса у облаку, када корисник систему приступа удаљено. Разлика између локалног и удаљеног режима односи се на комуникациони пут, а не на обим права који корисник има. У оба случаја захтев мора бити обрађен у складу са активним профилем, приступним правом, зоном ресурса и актуелним статусом профила.

Код управљања профилима комуникација је усмерена ка сервису у облаку, јер се тамо налази ауторитативни извор података о профилима и ACL правилима. Код извршавања команди комуникација се завршава на контролеру, јер он има локални модел система и примењује правила приступа над конкретним ресурсом. Оваква подела омогућава да се профили централизовано управљају, а да се приступ доследно проверава у локалном и удаљеном режиму рада.

На овај начин токови комуникације повезују управљање профилима у сервису у облаку, приказ активног профила у клијентској апликацији и примену приступних права на контролеру. Исти приступни контекст задржава се и у локалном и у удаљеном режиму рада.

5. Програмско решење

Након дефинисања концепта и архитектуре решења, у овом поглављу описује се програмска реализација механизма корисничких подулога у OBLO систему. За разлику од претходног поглавља, у коме је нагласак био на расподели одговорности између сервиса у облаку, контролера и клијентских апликација, овде се описују конкретни делови имплементације који омогућавају управљање профилима, пренос приступног контекста и примену приступних права.

Програмско решење реализовано је као проширење постојећег начина рада OBLO система. Када механизам корисничких подулога није активан, систем наставља да користи стандардне комуникационе токове, постојећу MQTT шему тема и уобичајен приказ функционалности у апликацији. Када је механизам активан, уводе се додатни подаци о активном профилу, ACL записи, прилагођен MQTT комуникациони контекст и претплате на догађаје у складу са зонама које су додељене активном профилу.

У овом поглављу не приказује се целокупна унутрашња имплементација OBLO система, већ делови који су директно повезани са реализацијом корисничких подулога. Обухваћени су модел података за корисничке профиле и ACL записе, REST API команде за управљање профилима, MQTT комуникација и идентификација активног профила, животни циклус профила, обрада догађаја, освежавање локалног стања и примена приступних права приликом извршавања захтева.

На тај начин ово поглавље повезује податке који се чувају у сервису у облаку, комуникациони контекст који се користи у размени порука са контролером и локално стање које клијентска апликација користи за приказ система. Описани механизми представљају основу за проверу да ли корисник, у оквиру активног профила, сме да приступи одређеној зони, прими догађаје из те зоне или изврши команду над конкретним ресурсом.

5.1 Преглед и обим имплементације решења

Програмско решење корисничких подулога реализовано је као проширење постојећег OBLO система, а не као засебан механизам. Основни циљ имплементације је да се постојећем моделу приступа дода подршка за више типова корисничких профила, приступна права, ограничење по зонама и временски ограничен приступ, уз очување стандардног начина рада система када функционалност подулога није активна.

Када механизам корисничких подулога није активан, апликација, сервис у облаку и контролер користе постојеће комуникационе токове и стандардну MQTT шему тема. У том режиму апликација не приказује екране за управљање профилима, не користи комуникациони контекст активне подулоге и не формира MQTT претплате на основу ACL података профила.

Када је функционалност омогућена на страни сервиса у облаку и када изабрани контролер подржава обраду подулога, систем користи додатне податке о активном профилу. Сервис у облаку управља животним циклусом профила и ACL подацима, контролер користи ажурирана правила приликом обраде захтева, док клијентска апликација приказује модел система, доступне функционалности и корисничке токове у складу са активним профилем.

Обим имплементације обухвата неколико међусобно повезаних целина. Прва целина је модел података за корисничке профиле и ACL записе. Друга целина су REST API команде којима се профили креирају, читају, верификују, мењају и бришу. Трећа целина је MQTT комуникација, у којој се захтеви и претплате на догађаје доводе у везу са активним профилем. Четврта целина је обрада догађаја и освежавање локалног стања након промена профила, ACL података или доступних контролера. Завршна целина је примена приступних права приликом обраде корисничких захтева.

Посебан значај у имплементацији има идентификација активног профила. Пошто је профил везан за конкретан контролер, исти кориснички налог може имати различите профиле у различитим инсталацијама. Због тога захтеви који се шаљу контролеру морају бити повезани са одговарајућим профилем, како би се команда, догађај или одговор обрадили у исправном приступном контексту.

У наставку поглавља детаљније су описани модел података, REST команде, MQTT комуникација, животни циклус профила, синхронизација локалног стања и обрада дозвола приликом извршавања корисничких захтева.

5.2 Модел података за корисничке профиле и ACL

Модел података представља основу програмског решења корисничких подулога, јер дефинише начин на који се у систему описује веза између корисничког налога, контролера, подулоге, приступних права и ресурса. За разлику од глобалног корисничког налога, подулога се дефинише у контексту једног конкретног контролера. Због тога исти корисник може имати различит приступ у различитим инсталацијама паметне куће.

Када корисник добије приступ контролеру, сервис у облаку формира податке који описују његову улогу у односу на тај контролер. У случају власника, приступ настаје приликом доделе контролера корисничком налогу. У случају станара, госта, управника некретнине или инсталатера, приступ настаје кроз токове управљања профилима. У оба случаја потребно је повезати корисника, контролер, тип подулоге и ACL правила која одређују доступне ресурсе и ниво приступа.

У моделу је важно разликовати идентификатор корисника од идентификатора активне подулоге. Поље `userProfileID` користи се као идентификатор корисника, односно корисничког налога. Са друге стране, `subroleUserId` представља идентификатор активне подулоге у контексту конкретног контролера. Ова вредност се користи у комуникацији са контролером како би се захтев обрадио у оквиру одговарајуће подулоге и одговарајућих ACL правила.

Ово раздвајање је важно зато што исти кориснички налог може имати више различитих приступних контекста. Један корисник може бити власник једног контролера, станар на другом контролеру и гост на трећем. У свим тим случајевима корисник је исти, али је његов `subroleUserId` различит у зависности од контролера и подулоге у којој приступа систему.

Основни модел корисничког профила у имплементацији је представљен објектом `UserProfileData`. Он садржи податке о власнику контролера, кориснику коме се приступ додељује, контролеру на који се приступ односи, типу подулоге, статусу верификације, трајању приступа када је оно применљиво и листи ACL записа.

Поље `primaryAccountID` представља налог власника контролера, односно налог који је примарно повезан са датом инсталацијом. Поље `secondaryAccountID` односи се на корисника коме се приступ додељује. Приликом креирања профила овај корисник се задаје преко адресе електронске поште, на коју се шаље OTP (енгл. One-Time Password) код за потврду приступа. Након обраде захтева, сервис у облаку формира приступни контекст који се касније користи при раду са изабраним контролером. Поље `gatewaySerial` представља идентификатор контролера на који се профил односи. У контексту OBLO система ова вредност одређује конкретну инсталацију паметне куће у којој корисник има одређену

подулогу. Поље `userProfileType` описује тип подулоге, као што су власник, управник некретнине, станар, гост или инсталатер. Поља `isVerified` и `isInstallerAllowed` користе се за статус профила, односно за проверу да ли је профил потврђен и да ли је инсталатерски приступ одобрен. Поље `duration` користи се код временски ограничених профила, пре свега код госта и инсталатера.

Сажет приказ основних поља модела `UserProfileData` дат је у Табели 5.1.

Поље	Опис
userProfileID	Идентификатор корисника, односно корисничког налога.
subroleUserId	Идентификатор активне подулоге у контексту конкретног контролера.
primaryAccountID	Идентификатор налога власника контролера.
secondaryAccountID	Корисник коме се приступ додељује; приликом креирања профила задаје се адресом електронске поште.
gatewaySerial	Идентификатор контролера на који се профил односи.
userProfileType	Тип подулоге, на пример власник, управник некретнине, станар, гост или инсталатер.
isVerified	Означава да ли је профил верификован и активан за употребу.
isInstallerAllowed	Означава да ли је инсталатерски приступ одобрен.
duration	Трајање приступа код временски ограничених профила.
listOfUserAccessControl	Листа ACL записа који дефинишу ресурсе и приступна права профила.

Табела 5.1 – Основна поља модела `UserProfileData`

Други важан део модела представља листа ACL записа. Она је унутар модела `UserProfileData` представљена пољем `listOfUserAccessControl`, при чему сваки елемент листе описује једно правило приступа. Појединачни ACL запис представља се моделом `UserAccessControl` и описује над којим ресурсом профил има одређени ниво права.

ACL подаци се размењују у формату JSON (енгл. JavaScript Object Notation). У оквиру ACL записа користе се поља `resourceType`, `resourceId` и `permission`. Поље `resourceType` означава тип ресурса на који се правило односи, при чему је у овом решењу најчешћа вредност `zone`. Поље `resourceId` означава конкретан ресурс, односно идентификатор зоне. Поље `permission` одређује ниво приступног права над тим ресурсом. Вредности приступног права могу бити `read`, `execute` или `manage`.

Пример једног ACL записа приказан је на Слици 5.1.

● Пример ACL записа за једну зону

```
{
  "resource_type": "zone",
  "resource_id": 12,
  "permission": "execute"
}
```

Слика 5.1 – Пример ACL записа за приступ једној зони

У приказаном примеру профил има право execute над зоном чији је идентификатор 12. То значи да корисник може да извршава дозвољене команде над уређајима који припадају тој зони, али не и над уређајима из зона које нису наведене у ACL листи активног профила.

Поље	Опис
resourceType	Тип ресурса на који се ACL запис односи, најчешће зона.
resourceId	Идентификатор конкретног ресурса, на пример зоне.
permission	Ниво приступа над ресурсом: read, execute или manage.

Табела 5.2 – Основна поља модела UserAccessControl

Приступно право није потпуно независно од типа подулоге. У имплементацији се основни ниво права одређује у складу са типом профила. Станар и гост имају право execute над додељеним зонама, јер треба да користе уређаје у свакодневном раду. Власник и инсталатер имају право manage, јер им је потребан шири обим управљања. Управник некретнине има посебну улогу у управљању профилима, али без директне контроле уређаја.

Овако дефинисан модел омогућава да се корисник, контролер, подулога, зона, приступно право и трајање приступа повежу у јединствену целину. Кориснички налог одређује ко приступа систему, контролер одређује инсталацију у којој се приступ примењује, subroleUserId одређује активни приступни контекст, ACL записи одређују ресурсе над којима та подулога важи, а приступно право одређује дозвољени тип операције.

Модел података представља заједничку основу за више делова система. Сервис у облаку користи га за чување и управљање профилима, клијентска апликација за приказ добијеног модела, активног профила и дозвољених UI опција, а контролер за примену

приступних права приликом обраде захтева. На тај начин један модел повезује управљање корисницима, ограничење приступа по зонама, MQTT комуникацију и извршавање команди над ресурсима система паметне куће.

5.3 REST API команде за управљање профилима

Управљање корисничким профилима у програмском решењу реализује се преко скупа REST API команди које омогућавају креирање, читање, верификацију, измену и брисање профила. Ове операције представљају комуникациони интерфејс између клијентске апликације и сервиса у облаку, у коме се профили централизовано чувају и обрађују.

У апликационом и SDK слоју (енгл. Software Development Kit, SDK) свака операција над корисничким профилем представљена је посебном командом. Команда садржи улазне параметре, назив операције, статус извршавања и податке који се добијају као резултат. Након што се команда формира, комуникациони слој је преводи у одговарајући REST API позив ка сервису у облаку. У случају успешног одговора, добијени подаци се парсирају и уписују у одговарајући модел, док се у случају грешке поставља статус грешке и формира порука која се може приказати кориснику или обрадити у апликацији.

Операције над профилима нису реализоване као један општи захтев, већ као више одвојених команди. Оваква организација омогућава да сваки део животног циклуса профила има јасно дефинисану улогу. Креирање профила користи се када овлашћени корисник додељује приступ другом налогу. Верификација профила користи се када је потребна потврда путем OTP кода. Измена профила омогућава промену подулоге, зона, ACL података или трајања приступа, док брисање профила уклања додељени приступ. Посебне команде постоје и за инсталатерски приступ, јер тај ток почиње захтевом за приступ контролеру и наставља се одобравањем или одбијањем од стране овлашћеног корисника.

Команде су организоване тако да прате основне корисничке токове у систему. Један део команди односи се на управљање профилима које покреће овлашћени корисник, други део на верификацију и поновно слање OTP кода, док је инсталатерски приступ издвојен у посебан ток. На тај начин се у програмском решењу раздвајају стандардно додељивање приступа, потврда приступа и привремено одобравање проширених права за сервисне потребе.

Сажет приказ REST API команди које се користе за управљање корисничким профилима дат је у Табели 5.3.

Команда	HTTP метода	API путања	Намена
CreateUserProfile Cmd	POST	/crm/userProfile/create	Креирање новог корисничког профила за изабрани контролер.
GetAllUserProfiles Cmd	GET	/crm/userProfile/list/<gatewayID>	Добијање листе профила који су дефинисани за један контролер.
GetUserProfileCmd	GET	/crm/userProfile/<userProfileID>	Добијање података о кориснику или профилу у складу са прослеђеним идентификатором.
VerifyUserProfileCmd	POST	/crm/userProfile/verify	Верификација профила употребом OTP кода.
ModifyUserProfile Cmd	PUT	/crm/userProfile/id/<userProfileID>	Измена постојеће подулоге, укључујући тип подулоге, ACL податке или трајање приступа.
DeleteUserProfileCmd	DELETE	/crm/userProfile/<userProfileID>	Брисање корисничког профила.
GetAllProfilesForOneUserCmd	GET	/crm/userProfile/id/getAllProfilesForOneUser	Добијање свих профила једног корисника, по потреби са додатним подацима о корисницима.
ResendOtpForUserProfileCmd	GET	/crm/userProfile/resendOTP/<userProfileID>	Поновно слање OTP кода за профил који још није верификован.
RequestInstallerAccessCmd	POST	/crm/userProfile/requestAccess/installer	Слање захтева за инсталатерски приступ контролеру.
AllowInstallerAccessCmd	POST	/crm/userProfile/requestAccess/installer/respond	Одобравање или одбијање захтева за инсталатерски приступ.

Табела 5.3 – REST API команде за управљање корисничким профилима

Команда за креирање профила користи се када овлашћени корисник додељује приступ другом корисничком налогу. Захтев садржи податке о власнику контролера, кориснику коме се приступ додељује, контролеру на који се профил односи, типу подулоге и листи ACL записа. Код профила са временским ограничењем, као што је гостујући профил, у захтев се укључује и трајање приступа.

Пример логичког садржаја захтева за креирање профила приказан је на Слици 5.2.

● CreateUserProfileCmd – креирање профила

```
{
  "primaryAccountID": "owner_account_id",
  "secondaryIdentity": "resident@example.com",
  "gatewaySerial": "GW123456",
  "userProfileType": "resident",
  "userAcl": [
    {
      "resource_type": "zone",
      "resource_id": 12,
      "permission": "execute"
    },
    {
      "resource_type": "zone",
      "resource_id": 15,
      "permission": "execute"
    }
  ],
  "duration": null
}
```

Слика 5.2 – Логички садржај захтева за креирање корисничког профила

У приказаном примеру формира се захтев за креирање профила станара за конкретан контролер. Захтев садржи податке који су потребни сервису у облаку да повеже власника контролера, корисника коме се приступ додељује, изабрани контролер, тип подулоге, приступна права и трајање приступа када је оно применљиво.

Вредност primaryAccountID представља налог власника контролера, односно налог који је примарно повезан са датом инсталацијом. Поље secondaryIdentity садржи адресу

електронске поште корисника коме се приступ додељује. Сервис у облаку на ту адресу шаље OTP код, који корисник касније користи за потврду приступа.

Поље `gatewaySerial` одређује контролер на који се приступ односи, док `userProfileType` означава тип подулоге која се креира. У приказаном примеру вредност `resident` означава да се креира профил станара. Листа `userAcl` садржи ACL записе који дефинишу зоне и приступна права додељена том профили.

У приказаном примеру профил има право `execute` над зонама са идентификаторима 12 и 15. То значи да станар може да извршава дозвољене команде над уређајима који припадају тим зонама. Пошто станар нема временски ограничен приступ, поље `duration` нема постављену вредност, односно има вредност `null`.

Након успешног креирања, сервис у облаку чува податке о додељеном приступу и формира приступни контекст који се касније користи при раду са изабраним контролером. Када се тај профил користи у комуникацији са контролером, активна подулога се идентификује вредношћу `subroleUserId`. На тај начин систем може да повеже корисника, контролер, подулогу и ACL правила која треба применити приликом обраде захтева.

Команде за читање профила користе се приликом приказа листе профила за један контролер, приказа података о конкретном кориснику или профили, као и добијања свих профила које један корисник има на различитим контролерима. Ово је важно зато што подулога није глобална улога корисника, већ важи у односу на конкретан контролер.

Верификација профила реализује се посебном командом и користи се када је потребна потврда путем OTP кода. Измена профила омогућава промену подулоге, додељених зона, ACL листе или трајања приступа, док брисање профила уклања право корисника да приступа изабраном контролеру у оквиру тог профила. Инсталатерски приступ је издвојен у посебан ток: инсталатер најпре шаље захтев за приступ контролеру, а овлашћени корисник тај захтев касније одобрава или одбија.

Све REST команде користе исти општи принцип обраде. Клијентска апликација иницира корисничку акцију и формира одговарајућу команду. Команда се затим шаље сервису у облаку као HTTP захтев. Након успешног одговора, добијени подаци се парсирају и уписују у одговарајући модел података. У случају грешке, команда добија статус грешке, а апликација може да прикаже одговарајућу поруку или да покрене додатну обраду.

REST API команде представљају управљачки део решења. Њима се креирају, мењају, читају и бришу профили, али се примена приступних права приликом извршавања команди над уређајима ослања на MQTT комуникацију, синхронизацију ACL података и проверу приступа на контролеру. Због тога REST слој представља основу за управљање профилима, док се правила приступа примењују у каснијим фазама рада система.

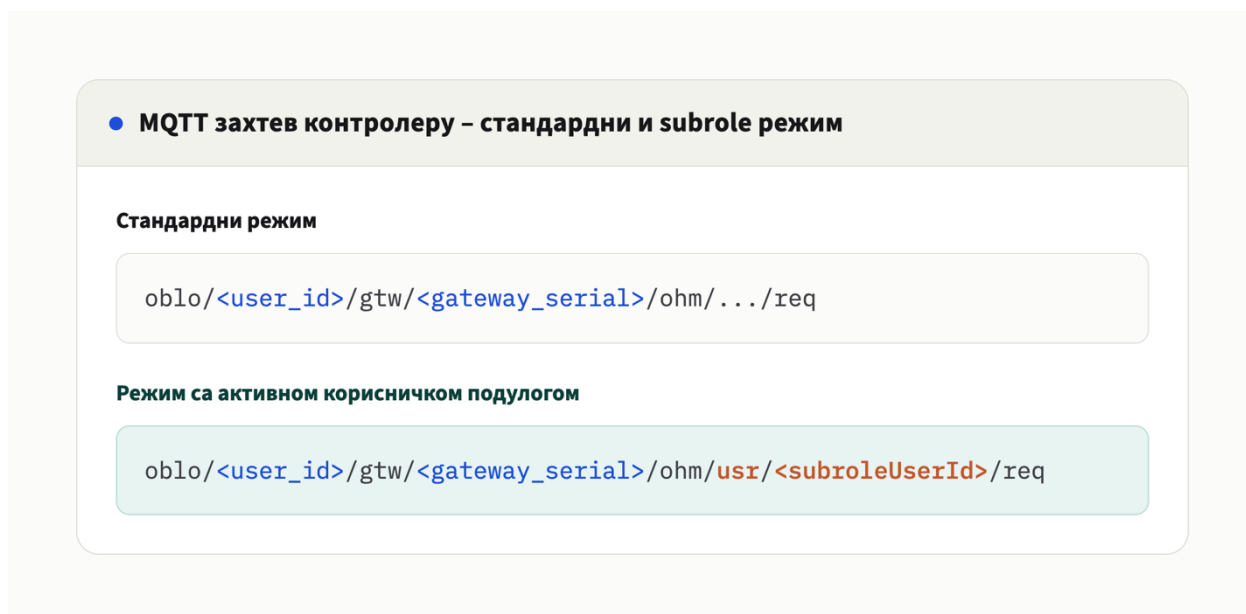
5.4 MQTT комуникација и идентификација активног профила

MQTT комуникација представља механизам преко кога се у OBLO систему размењују команде, одговори и догађаји између клијентске апликације, сервиса у облаку и контролера. У стандардном режиму рада, када механизам корисничких подулога није активан, користи се постојећа MQTT шема тема и комуникација се одвија у уобичајеном контексту корисника и изабраног контролера.

Увођењем корисничких подулога MQTT комуникација се проширује тако да захтев може бити повезан са активном подулогом корисника. То је неопходно зато што исти кориснички налог може имати различите приступне контексте на различитим контролерима. Због тога није довољно да захтев буде повезан само са корисником и контролером, већ је потребно знати и у којој подулози корисник шаље захтев.

Идентификатор активне подулоге у комуникационом слоју представљен је вредношћу `subroleUserId`. Ова вредност не представља глобални идентификатор корисничког налога, већ приступни контекст који корисник има за конкретан контролер. На тај начин систем може да одреди не само који корисник шаље захтев, већ и коју улогу тај корисник има у односу на изабрани контролер.

Разлика између стандардног режима и режима са активном корисничком подулогом може се приказати кроз структуру MQTT теме за захтеве ка контролеру. У стандардном режиму захтев се шаље у контексту корисника и контролера. У режиму са активном подулогом у путању MQTT теме додаје се сегмент `usr/<subroleUserId>`, чиме се захтев везује за активни приступни контекст.



Слика 5.3 – Структура MQTT теме за захтеве ка контролеру у стандардном режиму и режиму са активном подулогом

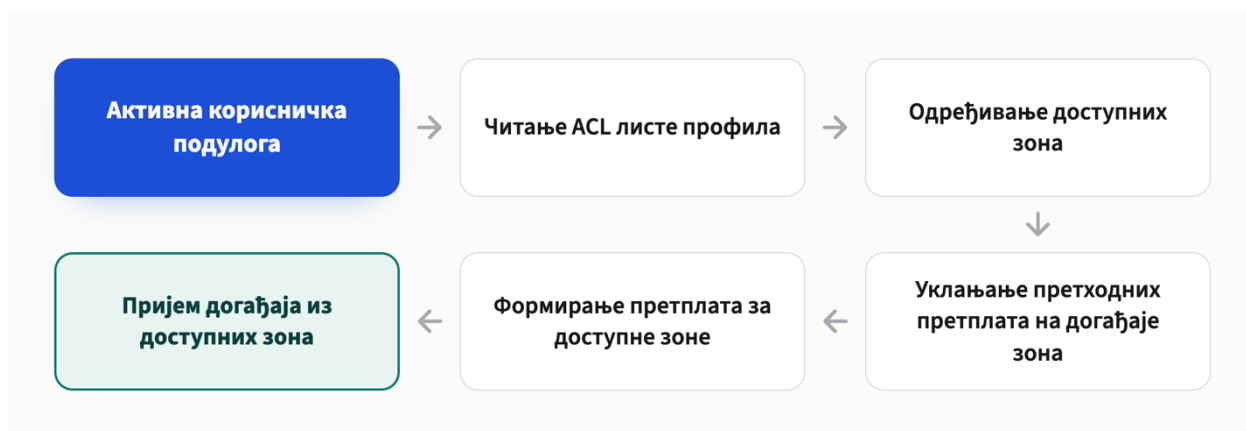
У стандардном режиму захтев се обрађује као захтев корисника који има уобичајен приступ контролеру. У режиму са активном подулогом, сегмент `usr/<subroleUserId>` омогућава контролеру да захтев повеже са конкретном подулогом и одговарајућим ACL правилима. Контролер на основу тог приступног контекста може да провери да ли је захтев дозвољен у односу на зону, тип ресурса, приступно право и актуелни статус профила.

Овај приступ омогућава да се исти комуникациони механизам користи и у стандардном режиму и у режиму са активним корисничким подулогама. Када `subroleUserId` није присутан, користе се стандардне MQTT теме. Када је `subroleUserId` присутан, захтев се обрађује у контексту активне подулоге. На тај начин се механизам корисничких подулога уводи као проширење постојеће MQTT шеме тема, без нарушавања рада система када функционалност није омогућена.

Поред слања команди, MQTT механизам користи се и за пријем догађаја. У режиму са активном подулогом претплате на догађаје морају бити усклађене са ACL листом профила. Ако профил има приступ само одређеним зонама, апликација треба да прима догађаје који се односе на те зоне. На пример, ако профил има ACL записе за зоне 12 и 15, формирају се претплате за догађаје из тих зона, док се догађаји из осталих зона не користе у комуникационом контексту активне подулоге.

У имплементацији се овај механизам реализује динамичким ажурирањем MQTT претплата. Када је потребно ускладити претплате са активним профилем, најпре се уклањају претходне претплате које се односе на догађаје зона. Након тога се, на основу актуелне ACL листе, формирају нове претплате за зоне којима профил има приступ. На тај начин се спречава да апликација настави да прима догађаје из зона које више нису доступне активном профилу.

Овај поступак може се приказати на следећи начин.



Слика 5.4 – Усклађивање MQTT претплата са ACL листом активног профила

Важно је нагласити да ограничење MQTT претплата не замењује проверу приступа на контролеру. Оно има улогу да апликација не прима и не приказује догађаје који нису релевантни за активни профил. Са становишта контроле приступа, одлука о томе да ли је команда дозвољена мора бити донета на контролеру, на основу активне подулоге, ACL правила, зоне ресурса и актуелног статуса профила.

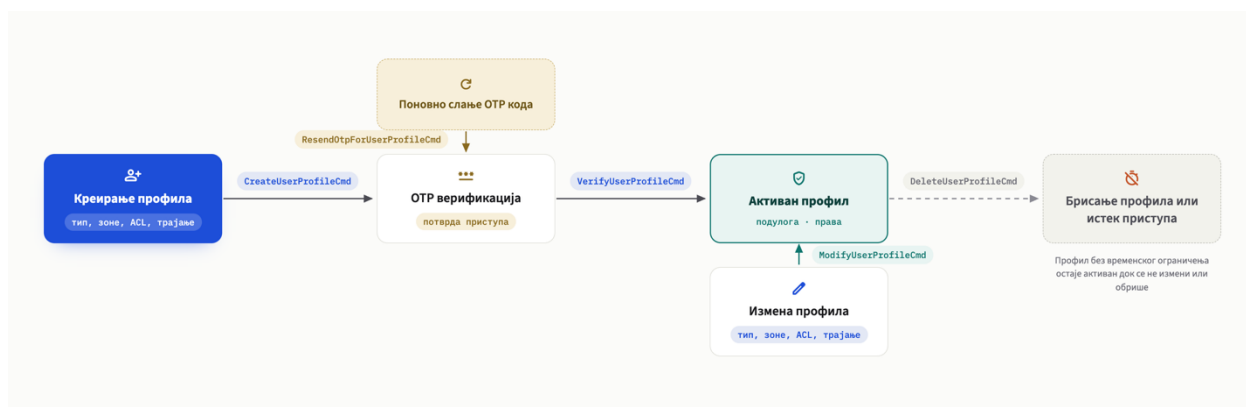
Приликом ажурирања претплата не уклањају се све MQTT теме. Основне теме потребне за комуникацију, системске догађаје и одговоре на захтеве остају активне. Динамички се мењају пре свега претплате које се односе на догађаје зона, јер оне директно зависе од ACL листе активног профила. На тај начин систем задржава стабилну комуникациону основу, док се пријем догађаја из зона прилагођава активној подулози.

Оваква MQTT организација омогућава да се модел корисничких профила примени и током рада система у реалном времену. REST API команде омогућавају управљање профилима у сервису у облаку, док MQTT комуникација омогућава да се команде и догађаји обрађују у односу на активну подулогу и њену ACL листу. На тај начин MQTT слој повезује модел подулога са стварним радом контролера.

5.5 Животни циклус корисничког профила

Животни циклус корисничког профила описује стања кроз која профил пролази од тренутка креирања до престанка важења приступа. Пошто је профил везан за конкретан контролер, свака промена профила утиче на приступ корисника тој инсталацији, а не на његов кориснички налог у целини. На тај начин корисник може имати активан приступ на једном контролеру, измењен приступ на другом и обрисан или истекао приступ на трећем.

Основни животни циклус профила обухвата креирање, верификацију, активну употребу, измену и брисање профила. Код временски ограничених профила животни циклус обухвата и истек приступа, док је код инсталатера ток додатно проширен захтевом за приступ и одобравањем од стране овлашћеног корисника.



Слика 5.5 – Животни циклус корисничког профила

Креирање профила представља почетну фазу животног циклуса. У овој фази овлашћени корисник додељује приступ другом корисничком налогу за изабрани контролер. Приликом креирања дефинишу се тип подулоге, додељене зоне, ACL правила и, ако је потребно, трајање приступа. Ови подаци се шаљу командом `CreateUserProfileCmd`, након чега сервис у облаку чува податке о додељеном приступу и припрема профил за даљу обраду.

Након креирања, профил не мора одмах бити потпуно активан. За профиле код којих је предвиђена потврда приступа користи се OTP верификација. Сервис у облаку шаље OTP код кориснику коме је приступ додељен, а корисник тај код уноси ради потврде приступа. Након успешне потврде профил се верификује командом `VerifyUserProfileCmd` и прелази у активно стање. Ако OTP код истекне или није примљен, може се покренути поновно слање кода командом `ResendOtpForUserProfileCmd`.

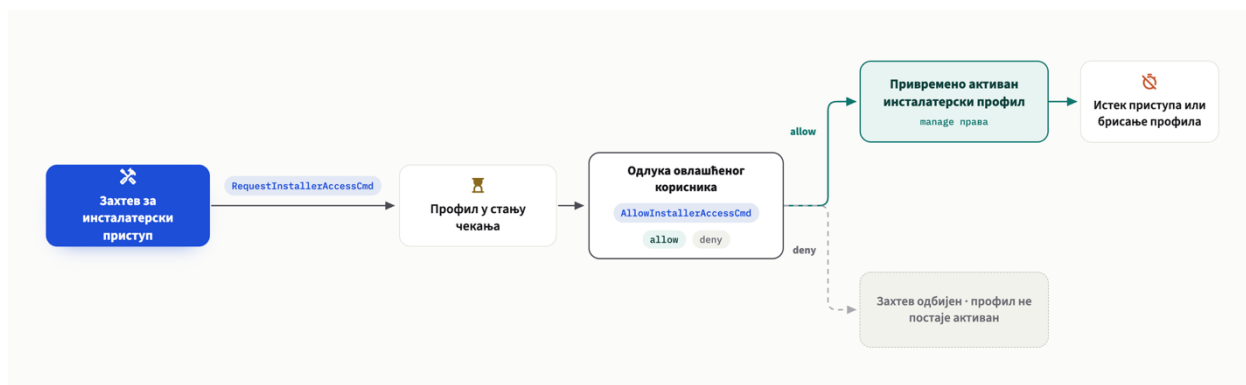
Када је профил успешно верификован и када су испуњени услови приступа, профил постаје активан. У активном стању профил се користи за приступ додељеним зонама, уређајима и функционалностима. Активни профил одређује коју подулогу корисник има на изабраном контролеру, којим зонама има приступ и које операције сме да извршава. У том стању се подаци о подулози и приступним правима користе приликом приказа система, формирања комуникационог контекста и провере приступних права.

Измена профила користи се када је потребно променити постојећа правила приступа. То може обухватити промену типа подулоге, додавање или уклањање зона, измену ACL листе или промену трајања приступа код привремених профила. Измена се извршава командом `ModifyUserProfileCmd`, након чега претходна правила више не треба да се користе, већ систем мора да ради са ажурираним подацима. Због тога измена профила захтева синхронизацију са компонентама које примењују или приказују приступна права.

Брисање профила представља завршну фазу животног циклуса у којој корисник губи приступ конкретном контролеру у оквиру тог профила. Брисање се извршава командом `DeleteUserProfileCmd`. Након тога профил више не треба да буде доступан за извршавање команди, приказ зона или пријем догађаја. Ако је обрисани профил припадао тренутно активном кориснику, потребно је освежити локално стање и листу доступних контролера.

Код гостујућих и инсталатерских профила животно циклус може се завршити и истеком приступа. У том случају профил престаје да важи након унапред дефинисаног времена. Истек приступа има исти практични ефекат као уклањање права: корисник више не треба да користи зоне, уређаје и функционалности које су биле доступне током активног периода. Овај механизам је посебно значајан за привремене кориснике, јер смањује потребу за ручним брисањем профила након завршетка боравка или сервисне интервенције.

Инсталатерски приступ има посебан животни циклус, приказан на Слици 5.6. За разлику од стандардних профила, инсталатер не почиње ток класичним креирањем профила од стране власника, већ слањем захтева за приступ конкретном контролеру. Захтев се шаље командом `RequestInstallerAccessCmd` и односи се на идентификатор контролера.



Слика 5.6 – Животни циклус инсталатерског приступа

Након слања захтева, профил се налази у стању чекања. У том стању инсталатер још увек нема активан приступ систему, већ се чека одлука овлашћеног корисника. Овлашћени корисник може да одобри или одбије приступ употребом команде `AllowInstallerAccessCmd`.

Ако је приступ одобрен, инсталатер добија привремено активан профил са `manage` правима потребним за подешавање, одржавање или сервисирање система. Овај приступ је временски ограничен и не треба да остане активан након завршетка сервисне интервенције. Након истека приступа или брисања профила, инсталатер више не треба да има могућност приступа контролеру.

Ако је захтев одбијен, инсталатерски профил не постаје активан. На тај начин се спречава да техничко лице добије приступ систему без одобрења овлашћеног корисника. Овај ток омогућава контролисано додељивање проширених права, али само у ситуацијама када је такав приступ заиста потребан.

Посебна вредност овако организованог животног циклуса је у томе што свака промена профила има јасно место у систему и може да покрене одговарајуће ажурирање осталих компоненти. Креирање и верификација профила утичу на то да корисник добије приступ изабраном контролеру, измена профила мења зоне, права или трајање приступа, док брисање и истек приступа уклањају могућност даљег коришћења тог профила. На тај начин животни циклус профила није само опис корисничког тока, већ и основа за синхронизацију локалног стања, MQTT претплата и ACL података који се користе приликом обраде захтева.

Фаза	Опис
Креирање профила	Формира се профил који повезује кориснички налог, контролер, подулогу и ACL правила.
ОТР верификација	Корисник потврђује профил употребом једнократне лозинке, ако је за тај тип профила потребна потврда.
Активан профил	Профил се користи за приступ додељеним зонама, уређајима и функционалностима.
Измена профила	Мењају се тип подулоге, ACL листа, додељене зоне или трајање приступа.
Брисање профила	Уклања се приступ корисника конкретном контролеру.
Истек приступа	Временски ограничен профил престаје да важи након дефинисаног периода.
Инсталатерски захтев	Инсталатер тражи приступ контролеру, а овлашћени корисник захтев одобрава или одбија.

Табела 5.4 – Фазе животног циклуса корисничког профила

Овако реализован животни циклус омогућава да се приступ корисника контролише током целог периода важења профила. Профил се не посматра као статичан запис, већ као објект чије стање може да се мења кроз корисничке токове, верификацију, измене ACL података, временско ограничење и брисање.

Креирање, верификација, измена, брисање или истек профила утичу на локално стање, листу доступних контролера, ACL податке и MQTT претплате. Због тога животни циклус профила није завршен само REST API операцијом, већ захтева механизам синхронизације и обавештавања компоненти система. Тај механизам, као и обрада системских догађаја након промена профила, описани су у наредном потпоглављу.

5.6 Синхронизација, догађаји и освежавање локалног стања

Након креирања, верификације, измене или брисања корисничког профила, није довољно да промена буде сачувана само у сервису у облаку. Подаци о профилу морају бити усклађени са локалним стањем клијентског слоја, MQTT претплатама, листом доступних контролера и подацима које контролер користи приликом примене приступних права. Због тога синхронизација представља важан део програмског решења корисничких подулога.

Основни разлог за синхронизацију је то што промена профила директно утиче на приступни контекст корисника. Ако се профилу дода нова зона, она треба да постане доступна након освежавања стања. Ако се зона уклони из ACL листе, корисник више не

треба да прима догађаје који се односе на ту зону. Ако се профил обрише, корисник више не треба да има приступ контролеру преко тог профила. Због тога свака промена профила мора да покрене одговарајуће освежавање података.

У систему се за обавештавање о променама користе догађаји који се односе на корисничке профиле. Најзначајнији су `CreateUserProfileEvent`, `EditUserProfileEvent`, `VerifyUserProfileEvent` и `DeleteUserProfileEvent`. Ови догађаји носе податке о профилу преко објекта `UserProfileData`, што омогућава да се након пријема догађаја ажурира локални модел или покрене додатна синхронизација.

Догађај креирања профила користи се да обавести систем да је формиран нови профил. Након пријема овог догађаја објављује се интерно обавештење о креирању профила, како би делови система који приказују листу профила могли да освеже приказ. У овом случају није неопходно одмах мењати целокупно локално стање контролера, већ је довољно обавестити релевантне делове клијентског слоја да је листа профила промењена.

Догађај измене профила има већи утицај на локални модел, јер измена може да промени тип подулуге, додељене зоне, ACL листу или трајање приступа. Због тога се након пријема `EditUserProfileEvent` догађаја подаци о профилу обрађују као ажурирана листа профила. На тај начин се локални модел усклађује са новим подацима, а затим се објављује интерно обавештење да је профил измењен.

Догађај верификације профила користи се када профил након ОТР потврде може да постане активан. Ова промена може утицати на листу контролера којима корисник има приступ, па се након пријема `VerifyUserProfileEvent` догађаја освежава листа контролера. Након преузимања ажурне листе контролера, поново се преузимају и профили корисника. На тај начин се обезбеђује да систем има актуелан преглед контролера и подулуга које су доступне пријављеном кориснику.

Најсложенија је обрада догађаја брисања профила. Када се прими `DeleteUserProfileEvent`, из података профила чита се ACL листа и за сваку зону из те листе уклања се MQTT претплата. Ово је важно зато што корисник након брисања профила више не треба да прима догађаје из зона које су биле доступне преко тог профила. Ако се обрисани профил односи на контролер са којим је тренутно успостављена веза, веза се прекида како би се спречило коришћење неважећег приступног контекста.

Поред тога, ако обрисани профил припада тренутно пријављеном кориснику, контролер се уклања из локалне листе доступних контролера. То значи да корисник више не треба да види контролер коме је приступ био омогућен само преко обрисаног профила. Након тога се поново преузимају сви профили корисника, како би локално стање било усклађено са стањем у сервису у облаку.

Сажет приказ обраде најважнијих догађаја дат је у Табели 5.5.

Догађај	Обрада
CreateUserProfileEvent	Објављује се интерно обавештење да је креиран нови профил и да приказ листе профила треба освежити.
EditUserProfileEvent	Ажурирају се подаци о профилу у локалном моделу и објављује се обавештење о измени профила.
VerifyUserProfileEvent	Освежава се листа контролера и поново се преузимају профили корисника.
DeleteUserProfileEvent	Уклањају се MQTT претплате за зоне из ACL листе, по потреби се затвара веза са контролером, уклања контролер из локалног стања и поново преузимају профили.
DataModelUpdatedEvent	Покреће се шира тиха синхронизација локалног модела система.

Табела 5.5 – Обрада догађаја који утичу на локално стање и приступни контекст

Поред догађаја који су директно повезани са профилима, значајан је и `DataModelUpdatedEvent`. Овај догађај не представља промену једног конкретног профила, већ сигнал да је потребно освежити шири локални модел система. Када систем није већ у процесу позадинске или тихе синхронизације, након овог догађаја покреће се тиха синхронизација. Њена улога је да се локални подаци о зонама, уређајима, стањима и другим елементима система ускладе са актуелним стањем.

Освежавање листе контролера има посебну улогу након верификације или брисања профила. У том поступку систем шаље команду за добијање листе контролера, након чега се добијени контролери уписују или ажурирају у локалној бази. Потом се покреће команда за добијање свих профила тренутног корисника. На тај начин се локални модел ажурира у два корака: прво се освежава листа контролера, а затим и подаци о профилима који су везани за те контролере.

Синхронизација локалног стања важна је и због MQTT комуникације. Пошто се претплате на догађаје формирају у складу са ACL листом активног профила, свака промена ACL података може захтевати измену претплата. Ако се профилу дода нова зона, потребно је омогућити пријем догађаја из те зоне. Ако се зона уклони или се профил обрише, претплата за ту зону мора бити уклоњена. На тај начин се спречава да корисник настави да прима догађаје из делова система којима више нема приступ.

Овај механизам показује да управљање профилима није изоловано од остатка система. REST API операција иницира промену, али се стварно стање система ажурира кроз

обраду догађаја, освежавање локалних података и усклађивање MQTT претплата. Због тога синхронизација представља везу између животног циклуса профила и примене приступних права у реалном раду система.

На овај начин се обезбеђује да клијентски слој, сервис у облаку и контролер раде са усклађеним подацима. Када се профил креира, измени, верификује или обрише, промена се одражава на приказ профила, листу доступних контролера, ACL податке и комуникацију са контролером. У наредном потпоглављу описује се како се тако синхронизовани подаци користе приликом извршавања команди и примене приступних права.

5.7 Извршавање команди и примена приступних права

Извршавање команди представља завршни део примене механизма корисничких подулога. У претходним потпоглављима описани су модел профила, ACL записи, REST API команде, MQTT комуникациони контекст и синхронизација локалног стања. Сви ови делови омогућавају да се кориснички захтев, у тренутку извршавања, обради у складу са активном подулогом, додељеним зонама, приступним правима и актуелним статусом профила.

Кориснички захтев може имати различиту намену. Неке операције односе се на читање података, као што су добијање модела зона, уређаја или тренутног стања. Друге операције мењају стање система, на пример укључивање уређаја, промена вредности сервиса или покретање неке акције. Посебну групу чине управљачке и административне операције, као што су управљање конфигурацијом или сервисне операције. Због тога се сваки захтев мора посматрати у односу на тип операције коју покушава да изврши.

Да би се приступна права доследно применила, свака операција мора бити повезана са одговарајућим нивоом права који је потребан за њено извршавање. Операције које само читају стање система не захтевају исти ниво овлашћења као операције које мењају стање уређаја или конфигурацију система. Због тога се у програмском решењу захтеви не посматрају само према ресурсу на који се односе, већ и према ефекту који могу имати над тим ресурсом.

Сажет приказ односа између типа операције, примера захтева и потребног приступног права дат је у Табели 5.6.

Тип операције	Пример	Потребно право
Читање података	GetObjectDetailedCmd за добијање детаљних података о објекту	read
Извршавање команде	SetServiceValueCmd за промену вредности сервиса уређаја	execute
Управљачка операција	DeleteZoneControllerCmd за брисање зонског контролера	manage

Табела 5.6 – Однос типа операције и потребног приступног права

Наведене команде представљају илустративне примере различитих типова операција које се могу појавити приликом рада са системом. Команда GetObjectDetailedCmd представља пример операције читања, јер се користи за добијање детаљних података о објекту без промене његовог стања. За такве операције довољно је право read, под условом да се објекат налази у зони која је доступна активном профилу.

Команда SetServiceValueCmd представља пример операције која мења стање уређаја, па захтева право execute над зоном којој тај уређај припада. Са друге стране, команда DeleteZoneControllerCmd представља управљачку операцију, јер може утицати на конфигурацију система и доступност ресурса. Због тога се такве операције везују за право manage и треба да буду доступне само подулогама којима је у имплементацији дозвољен шири обим управљања.

Поред типа операције, приликом примене приступних права мора се узети у обзир и ресурс на који се захтев односи. Ако профил има право execute над једном зоном, то не значи да може да извршава команде над уређајима из свих зона. Право важи само у оквиру ресурса који је наведен у ACL запису. Због тога се при обради захтева проверава и да ли уређај, зонски контролер или други ресурс припада зони која је додељена активном профилу.

Када је активан механизам корисничких подулога, захтев који се шаље контролеру мора бити доведен у везу са активним приступним контекстом. У MQTT комуникацији овај контекст се преноси преко вредности subroleUserId. На тај начин контролер не обрађује захтев само као захтев одређеног корисничког налога, већ као захтев корисника у конкретној подулози на конкретном контролеру.

Приликом обраде захтева контролер користи синхронизоване податке о профилу и ACL правилима. На основу активне подулоге одређује се ACL листа која важи за тај приступни контекст. Затим се захтев доводи у везу са ресурсом на који се односи. Ако је ресурс уређај, битно је којој зони тај уређај припада. Ако је ресурс зона, провера се односи

директно на идентификатор те зоне. Захтев може бити извршен само ако активна подулога има одговарајући ACL запис и ако је ниво права довољан за тражену операцију.

Логички ток примене приступних права приликом обраде захтева приказан је у Табели 5.7.

Корак	Обрада
Пријем захтева	Контролер прима MQTT захтев из стандардног режима или режима са активном подулогом.
Идентификација приступног контекста	Ако је присутан subroleUserId, захтев се повезује са активном подулогом за изабрани контролер.
Провера статуса профила	Користи се актуелно синхронизовано стање профила, укључујући верификацију, брисање или истек приступа.
Одређивање ресурса	Из захтева се одређује уређај, зона, зонски контролер или други ресурс на који се операција односи.
Провера зоне	Проверава се да ли ACL листа активне подулоге садржи зону којој ресурс припада.
Провера права	Проверава се да ли право read, execute или manage одговара типу тражене операције.
Резултат обраде	Захтев се извршава, одбија или се тражени ресурс не укључује у одговор.

Табела 5.7 – Логички ток примене приступних права приликом обраде захтева

Овакав ток омогућава да се сваки захтев обради у односу на активни приступни контекст. На пример, команда SetServiceValueCmd може бити извршена само ако активна подулога има право execute над зоном којој уређај припада. Ако профил има само право read, команда не треба да доведе до промене стања уређаја. Ако профил има право execute, али над другом зоном, захтев такође не треба да буде извршен, јер ACL правило не важи над ресурсом на који се команда односи.

Сличан принцип важи и за читање података. Ако активна подулога има приступ само одређеним зонама, одговор система треба да буде усклађен са тим приступом. Корисник не треба да добије податке о ресурсима који припадају зонама које нису део његове ACL листе. На тај начин се приступна права примењују и приликом формирања одговора, а не само приликом извршавања команди које мењају стање система.

Управљачке операције захтевају додатну пажњу, јер могу утицати на конфигурацију система или на права других корисника. Оне обухватају радње као што су, измена конфигурације, брисање зонских контролера или сервисна подешавања. За такве операције

потребно је право manage, али и одговарајући тип подулоге. На пример, управник некретнине може имати улогу у управљању профилима, док гост или станар не треба да имају приступ административним функционалностима.

Провера приступа не сме зависити само од корисничког интерфејса. Клијентска апликација треба да прикаже добијени модел система и доступне UI опције у складу са активном подулогом, али то није довољно као једини механизам контроле приступа. Контролер мора да примени ACL правила приликом саме обраде захтева, јер се на том нивоу доноси одлука да ли операција над конкретним ресурсом сме да буде извршена.

Примена приступних права мора бити доследна без обзира на начин приступа систему. Корисник може приступити контролеру локално, када се налази у истој мрежи, или удаљено, када комуникација иде преко сервиса у облаку. Разлика између ова два режима односи се на комуникациони пут, а не на обим права. Исти активни приступни контекст, ACL правила и статус профила морају важити у оба режима рада.

У овом раду се не приказује унутрашња имплементација сваког алгорита на контролеру, већ податковни и комуникациони контекст који омогућава примену приступних права. Тај контекст обухвата активну подулогу, subroleUserId у MQTT комуникацији, ACL записе, зону ресурса, ниво приступног права и актуелно стање профила. На основу тих података контролер може да одлучи да ли се захтев извршава, одбија или се део података не укључује у одговор.

Извршавање команди и примена приступних права представљају завршну тачку програмског решења. Модел профила дефинише корисника, контролер и подулогу, ACL листа дефинише доступне ресурсе и права, MQTT комуникација преноси активни приступни контекст, а синхронизација обезбеђује да све компоненте користе ажурне податке. На тај начин корисничке подулоге не представљају само механизам за управљање профилима, већ основу за ограничено и контролисано коришћење ресурса система паметне куће.

6. Тестирање система и резултати

У овом поглављу приказано је тестирање реализованог механизма корисничких подулога у OBLO систему. Циљ тестирања је да се провери управљање профилима, ограничење приступа по зонама, временски ограничен приступ, различити нивои права и примена ACL правила приликом обраде захтева.

Тестирање је организовано кроз конкретне сценарије. За сваки тест наведени су улазни услови, очекивани резултат, добијени резултат и статус. Поред функционалних тестова, извршено је и мерење времена одзива за синхронизацију локалног модела и извршавање команде, у стандардном режиму и у режиму са активном корисничком подулогом.

6.1 План тестирања

План тестирања формиран је на основу критеријума решења дефинисаних у потпоглављу 3.6 и програмских целина описаних у претходном поглављу. Циљ није био да се тестира свака појединачна унутрашња функција система, већ да се провере сценарији који су најважнији за рад механизма корисничких подулога: управљање профилима, ограничење приступа по зонама, временски ограничен приступ, MQTT догађаји, различити нивои права и примена ACL правила на контролеру.

Тестови су организовани тако да прате стварне корисничке токове у систему. Најпре се проверава да ли се профил може креирати и верификовати, затим да ли се измене профила одражавају на доступне зоне и локално стање, а потом да ли систем правилно реагује када корисник покуша да приступи ресурсу или изврши команду за коју нема одговарајуће право. Поред функционалних тестова, предвиђено је и мерење времена одзива за синхронизацију локалног модела и извршавање команде, како би се упоредио рад система са активним подулогама и без њих.

Сажет приказ плана тестирања дат је у Табели 6.1.

Ознака	Област тестирања	Конкретна провера	Критеријум успешности
T1	Животни циклус профила	Креирање, верификација, измена и брисање профила. ОТП	Профил пролази кроз очекивана стања, а промене се одражавају на приступ корисника.
T2	Ограничење по зонама	Провера приступа додељеним и недодељеним зонама.	Активни профил користи само зоне наведене у ACL листи.
T3	MQTT догађаји	Провера пријема догађаја из зона које јесу и нису у ACL листи.	Апликација прима догађаје само из зона доступних активном профилу.
T4	Временски ограничен приступ	Провера гостујућег и инсталатерског профила пре и после истека.	Привремени профил важи само током дефинисаног периода.
T5	Нивои права	Провера read, execute и manage права на конкретним командама.	Сваки ниво права дозвољава само одговарајући тип операције.
T6	Провера на контролеру	Покретање команде која није дозвољена активном профилу.	Недозвољена команда се не извршава, а стање ресурса остаје непромењено.
T7	Време одзива	Мерење синхронизације и извршавања команде са подулогом и без подулоге.	Додатна обрада подулога не нарушава очекиван рад система.

Табела 6.1 – План тестирања механизма корисничких подулога

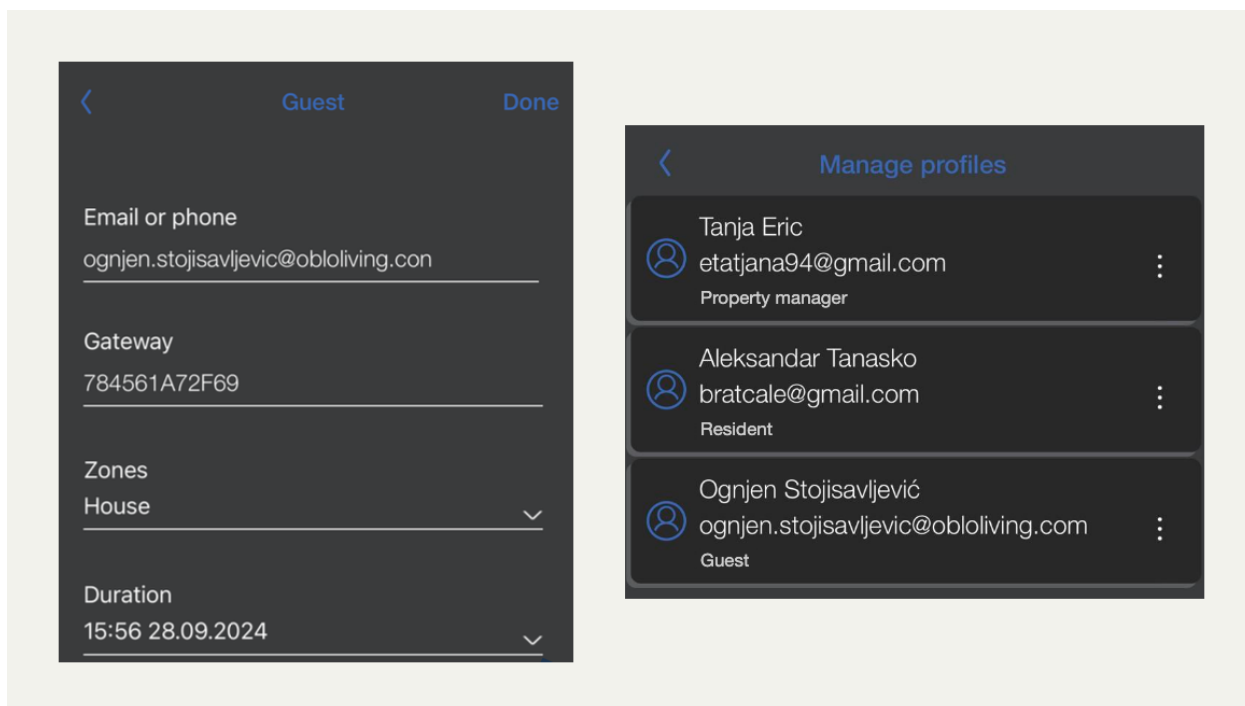
Овако дефинисан план тестирања покрива критеријуме решења из потпоглавља 3.6 кроз конкретне проверљиве сценарије. Критеријуми као што су најмање привилегије, доследна примена права и синхронизација података не посматрају се као један изолован тест, већ се проверавају кроз више сценарија: ограничење по зонама, MQTT догађаје, проверу различитих нивоа права и одбијање недозвољених команди на контролеру.

6.2 Тестирање животног циклуса профила

Ово тестирање обухвата креирање, ОТР верификацију, измену и брисање корисничког профила. Циљ је да се провери да ли се промене профила правилно чувају и да ли утичу на приступ корисника конкретном контролеру.

Тест	Улазни услови	Очекивани резултат	Добијени резултат	Статус
Креирање профила	Власник има приступ контролеру и уноси податке корисника, тип подулоге и ACL листу.	Профил је креиран у сервису у облаку и приказан у листи профила.	Профил је креиран и приказан у листи профила за изабрани контролер.	Прошао
Слање ОТР кода	Профил је креиран за корисника који треба да потврди приступ.	Кориснику се шаље ОТР код.	ОТР код је послат на адресу електронске поште задату приликом креирања профила.	Прошао
Верификација профила	Корисник има важећи ОТР код.	Профил постаје верификован и активан.	Након уноса ОТР кода профил је означен као верификован и корисник може да приступи контролеру.	Прошао
Измена профила	Профил је активан и има додељене ACL податке.	Измењени подаци се примењују након синхронизације.	Након измене профила систем користи ажуриране зоне, права или трајање приступа.	Прошао
Брисање профила	Профил је активан и има приступ контролеру.	Профил се уклања, а приступ контролеру више није доступан.	Профил је уклоњен из листе профила, приступ је укинут и локално стање је освежено.	Прошао

Табела 6.2 – Тестирање животног циклуса корисничког профила



Слика 6.1 – Креирање и преглед верификованих корисничких профила

Резултати показују да се профил креира и користи у контексту изабраног контролера, а не као глобална улога корисничког налога.

6.3 Тестирање ограничења приступа по зонама и MQTT догађаја

Ово тестирање проверава да ли активни профил има приступ само зонама које су наведене у његовој ACL листи. Провера обухвата приказ доступних ресурса, пријем MQTT догађаја и ажурирање MQTT претплата након измене ACL података.

У редовном раду апликација не приказује зоне којима активни профил нема приступ. У сврху тестирања, у тестном окружењу је омогућен приказ недодељене зоне, како би се проверило да ограничење није само визуелно, већ да се одражава и на приступни контекст. Само извршавање команди над дозвољеним и недозвољеним зонама обрађено је у потпоглављу 6.5.

Поред приказа зона, посматране су и MQTT претплате које се формирају на основу ACL листе активног профила. Додавањем зоне очекује се формирање нове претплате, док се уклањањем зоне очекује уклањање одговарајуће претплате, тако да апликација прима догађаје само из тренутно доступних зона.

Тест	Улазни услови	Очекивани резултат	Добијени резултат	Статус
Приказ додељене зоне	Активни профил има приступ зони 12.	Ресурси из зоне 12 су доступни активном профилу.	Ресурси из зоне 12 су приказани у моделу који је достављен активном профилу.	Прошао
Провера недодељене зоне	Активни профил има приступ само зони 12.	Ресурси из зоне 15 нису доступни активном профилу.	Ресурси из зоне 15 нису доступни у редовном приказу активног профила.	Прошао
Приказ недодељене зоне у тестном окружењу	Активни профил има приступ само зони 12, док је зона 15 приказана само у сврху теста.	Зона 15 се може користити само за проверу ограничења, али не постаје део стварног приступног контекста профила.	Зона 15 је приказана у тестном окружењу, али није додата у ACL листу активног профила.	Прошао
Догађај из додељене зоне	Активни профил има приступ само зони 12.	Апликација прима MQTT догађај из зоне 12.	Догађај из зоне 12 је примљен и приказано је ажурирано стање.	Прошао
Догађај из недодељене зоне	Активни профил има приступ само зони 12.	Апликација не прима MQTT догађај из зоне 15.	Догађај из зоне 15 није примљен у контексту активног профила.	Прошао
Додавање зоне у ACL листу	Профилу се додаје зона 15.	Након измене ACL листе формира се MQTT претплата за зону 15.	Након додавања зоне, активне MQTT претплате садрже теме за зоне 12 и 15.	Прошао
Уклањање зоне из ACL листе	Из ACL листе се уклања зона 15.	MQTT претплата за зону 15 се уклања.	Након уклањања зоне, активна остаје претплата за зону 12, док је претплата за зону 15 уклоњена.	Прошао

Табела 6.3 – Тестирање ограничења приступа по зонама и MQTT догађаја

● Усклађивање MQTT претплата са ACL листом активног профила		
СТАЊЕ	ACL ЗОНЕ	АКТИВНЕ MQTT ПРЕТПЛАТЕ
Пре измене	[12]	/ohm/azc/12/evt
После додавања зоне	[12, 15]	/ohm/azc/12/evt /ohm/azc/15/evt
После уклањања зоне	[12]	/ohm/azc/12/evt /ohm/azc/15/evt

ИСЕЧАК АНОНИМИЗОВАНОГ ТЕСТНОГ ЛОГА НАКОН ИЗМЕНЕ ПРОФИЛА И УКЛАЊАЊА ЗОНЕ 15

```
[ACL] Updated ACL: permission=execute, zones=[12]
[MQTT] manageSubscriptionForTopicWithZoneIds zoneIds=[12]
[MQTT] Removing previous /ohm/azc/ subscriptions
[MQTT] Removed topic: /oblo/user_1001/gtw/GW-TEST-01/ohm/azc/12/evt
[MQTT] Removed topic: /oblo/user_1001/gtw/GW-TEST-01/ohm/azc/15/evt
[MQTT] Adding zone event topic: /oblo/user_1001/gtw/GW-TEST-01/ohm/azc/12/evt
```

Слика 6.2 – Усклађивање MQTT претплата са ACL листом активног профила

Резултати показују да ACL листа активног профила утиче на доступност зона и на пријем MQTT догађаја. Након додавања зоне у ACL листу формира се одговарајућа MQTT претплата, док се након уклањања зоне та претплата уклања. На тај начин апликација прима догађаје само из зона које су део тренутног приступног контекста активног профила.

6.4 Тестирање временски ограниченог приступа

Ово тестирање обухвата профиле чији приступ важи само током дефинисаног периода. Провера је извршена за гостујући профил и инсталатерски приступ, јер су то типични случајеви у којима корисник не треба да има трајан приступ контролеру.

Циљ теста је да се провери да ли је приступ доступан у периоду важења профила, као и да ли се након истека или одбијања приступа профил више не може користити. Код инсталатерског приступа посебно је проверен ток у ком инсталатер шаље захтев, а овлашћени корисник тај захтев одобрава или одбија.

Поред провере самог истека приступа, посматрано је и да ли се промена статуса профила одражава на приказ доступних контролера, зона и функционалности у апликацији. На тај начин се проверава да привремени приступ није само временски податак у профилу, већ услов који утиче на стварну могућност коришћења система.

Тест	Улазни услови	Очекивани резултат	Добијени резултат	Статус
Активан гостујући профил	Гост има додељену зону и важеће трајање приступа.	Гост може да користи додељене ресурсе током важења профила.	Гостујући профил је активан и доступни су само ресурси из додељене зоне.	Прошао
Истек гостујућег профила	Гостујућем профилу је истекло дефинисано трајање.	Приступ више није доступан.	Након истека гостујући профил више не омогућава приступ контролеру.	Прошао
Одобрен инсталатерски приступ	Инсталатер шаље захтев, а овлашћени корисник га одобрава.	Инсталатер добија привремен приступ контролеру.	Након одобравања, инсталатерски приступ је активан у дефинисаном периоду.	Прошао
Одбијен инсталатерски приступ	Инсталатер шаље захтев, а овлашћени корисник га одбија.	Инсталатер не добија приступ контролеру.	Инсталатерски профил није активиран и приступ контролеру није омогућен.	Прошао
Догађај из недодељене зоне	Истек инсталатерског приступа	Приступ више није доступан.	Након истека инсталатерски профил више не омогућава приступ контролеру.	Прошао

Табела 6.4 – Тестирање временски ограниченог приступа

Резултати показују да временски ограничени профили омогућавају приступ само у дефинисаном периоду. Након истека гостујућег или инсталатерског приступа, профил више не омогућава коришћење контролера у том приступном контексту.

6.5 Тестирање различитих нивоа права и провере на контролеру

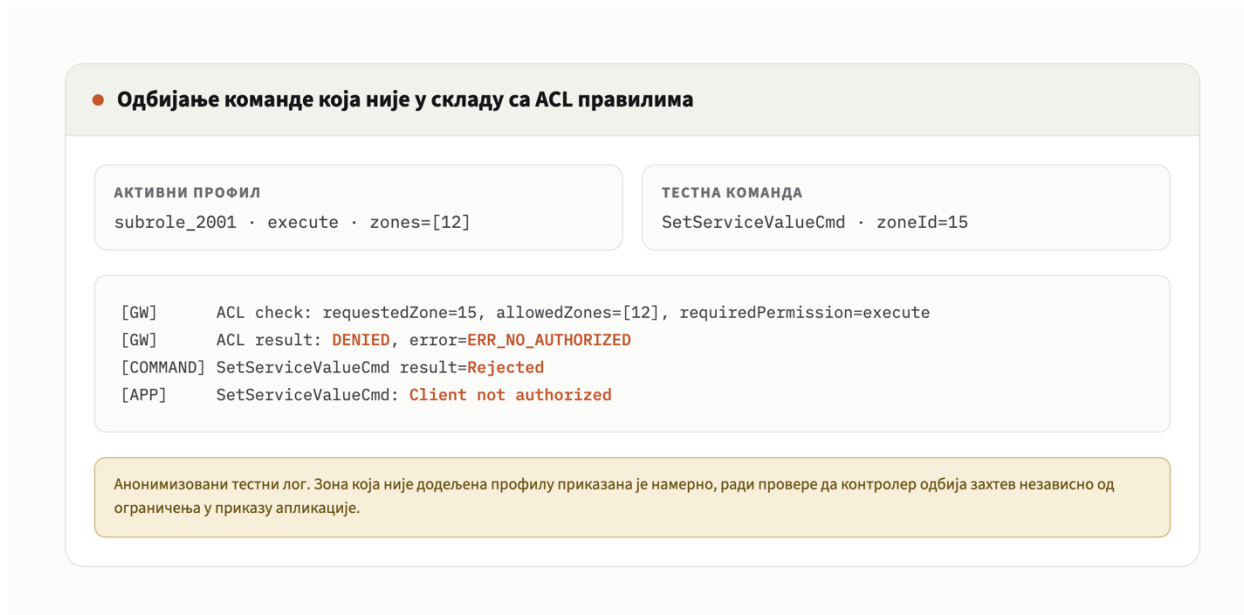
Ово тестирање проверава да ли систем правилно разликује права `read`, `execute` и `manage`. За проверу су коришћене конкретне команде које представљају различите типове операција: `GetObjectDetailedCmd` за читање података, `SetServiceValueCmd` за измену стања уређаја и `DeleteZoneControllerCmd` за управљачку операцију.

Посебно је проверено да ли контролер одбија захтев који није у складу са ACL правилима активног профила. У том тесту редовно UI ограничење је намерно заобиђено, како би се проверило да ли се команда одбија у извршном слоју система, а не само сакривањем опције у апликацији.

ACL	Захтев	Очекивани резултат	Добијени резултат	Статус
read над зоном 12	<code>GetObjectDetailedCmd</code> за објекат у зони 12	Подаци о објекту се враћају.	Систем је вратио детаљне податке о објекту из зоне 12.	Прошао
read над зоном 12	<code>SetServiceValueCmd</code> за уређај у зони 12	Команда се не извршава јер профил нема <code>execute</code> право.	Команда није извршена и стање уређаја је остало непромењено.	Прошао
execute над зоном 12	<code>SetServiceValueCmd</code> за уређај у зони 12	Команда се извршава.	Команда је извршена и стање уређаја је промењено.	Прошао
execute над зоном 12	<code>SetServiceValueCmd</code> за уређај у зони 15	Команда се не извршава јер зона није у ACL листи.	Команда није извршена јер уређај припада недодељеној зони.	Прошао
manage над зоном 0, односно целим системом	<code>DeleteZoneControllerCmd</code>	Управљачка операција је дозвољена само профилу који има право <code>manage</code> над целим системом и одговарајући тип подулоге.	Операција је доступна и извршена само у приступном контексту који има право <code>manage</code> над зоном 0.	Прошао

read над зоном 12	SetServiceValueCmd послата након заобилажења редовног UI ограничења	Контролер одбија команду јер активно право није довољно за измену стања уређаја.	Контролер није извршио команду, а стање уређаја је остало непромењено.	Прошао
execute над зоном 12	SetServiceValueCmd за уређај у зони 15 након приказа недодељене зоне у тестном окружењу	Контролер одбија команду јер зона 15 није део ACL листе активног профила.	Контролер није извршио команду јер ресурс припада зони која није додељена активном профилу.	Прошао

Табела 6.5 – Тестирање различитих нивоа приступних права и провере на контролеру



Слика 6.3 – Одбијање команде која није у складу са ACL правилима

Резултати показују да read омогућава читање података, execute омогућава измену стања уређаја у дозвољеној зони, док manage омогућава управљачке операције у складу са типом подулуге. Покушај извршавања команде без одговарајућег права или над ресурсом из недодељене зоне није довео до промене стања уређаја.

Овим је потврђено да контрола приступа није заснована само на клијентској апликацији. Апликација може да ограничи приказ и доступне UI опције, али коначна провера приступа врши се приликом обраде захтева на контролеру.

6.6 Мерење времена одзива

Поред функционалних тестова, измерено је време одзива за две операције: синхронизацију локалног модела и извршавање команде `SetServiceValueCmd`. Мерења су извршена у стандардном режиму и у режиму са активном корисничком подулогом, како би се проверило да ли додатна обрада приступног контекста и ACL правила утиче на рад система.

Време синхронизације мерено је од тренутка покретања синхронизације до завршетка ажурирања локалног модела. Време извршавања команде мерено је од тренутка слања захтева до пријема одговора о извршењу команде. Сваки сценарио је поновљен 20 пута, а у табели су приказане просечне вредности. Пошто време појединачног позива зависи од тренутног стања система, мреже и обраде на контролеру, мање разлике између мерења тумаче се као нормалне варијације у раду система.

Сценарио	Број мерења	Просечно време у стандардном режиму [ms]	Просечно време у subrole режиму [ms]	Разлика [ms]	Релативна разлика [%]
Синхр. система	20	5694	5638	-56	-0,98
SetService ValueCmd	20	220	240	20	9,09

Табела 6.6 – Упоредни приказ времена одзива у стандардном режиму и режиму са активном подулогом

Измерене вредности показују да су времена синхронизације локалног модела у оба режима приближна. У стандардном режиму просечно време синхронизације износило је 5694 ms, док је у режиму са активном подулогом износило 5638 ms. Разлика од -56 ms, односно -0,98%, не указује на стварно убрзање система, већ представља нормалну варијацију просечних вредности добијених мерењем.

Код извршавања команде `SetServiceValueCmd` просечно време у стандардном режиму износило је 220 ms, док је у режиму са активном подулогом износило 240 ms. Повећање од 20 ms, односно 9,09%, представља мали и прихватљив утицај на време одзива. Ова разлика је очекивана, јер се у режиму са активном подулогом додатно обрађују

приступни контекст и ACL правила, док се сама команда и даље шаље постојећим MQTT комуникационим механизмом.

На основу добијених резултата може се закључити да механизам корисничких подулога није значајно утицао на време синхронизације локалног модела, док је код извршавања појединачне команде измерено мало повећање времена одзива. У оба случаја вредности су у очекиваним границама рада система паметне куће.

6.7 Анализа резултата

Резултати тестирања показују да реализовани механизам корисничких подулога подржава основне токове управљања профилима. Креирање, ОТР верификација, измена и брисање профила успешно мењају приступни контекст корисника у односу на изабрани контролер.

Ограничење приступа по зонама потврђено је кроз приказ доступних ресурса, пријем MQTT догађаја и извршавање команди. Активни профил добија приступ само зонама које су наведене у његовој ACL листи, док ресурси из недодељених зона нису доступни.

Тестирање различитих нивоа права показало је да `read`, `execute` и `manage` имају различито понашање у систему. Право `read` омогућава читање података, `execute` омогућава извршавање команди над уређајима у дозвољеним зонама, док `manage` омогућава управљачке операције у складу са типом подулоге.

Посебно је потврђено да контрола приступа не зависи само од корисничког интерфејса. Када је покренута команда која није била у складу са ACL правилима активног профила, контролер није извршио захтев и стање уређаја је остало непромењено.

Мерења времена одзива показала су да увођење подулога има прихватљив утицај на рад система. Просечно време синхронизације локалног модела било је приближно у оба режима рада: у стандардном режиму износило је 5694 ms, а у режиму са активном подулогом 5638 ms. Разлика од -56 ms, односно -0,98%, представља нормалну варијацију мерења и не указује на суштинско убрзање или успорење система. Код извршавања команде `SetServiceValueCmd` просечно време је повећано са 220 ms на 240 ms, односно за 20 ms или 9,09%. На основу ових резултата може се закључити да додатна обрада приступног контекста и ACL правила не нарушава очекивани рад система.

7. Закључак

У овом раду представљено је програмско решење механизма корисничких подулога у OBLO систему за аутоматизацију паметне куће. Основни циљ рада био је да се постојећи модел приступа прошири тако да различити корисници не морају имати исти ниво контроле над целим системом, већ да се њихов приступ одређује у односу на конкретан контролер, тип подулоге, додељене зоне, приступна права и период важења профила.

У оквиру рада анализирани су захтеви који се јављају у паметним кућама са више корисника, као што су власници, станари, гости, управници некретнина и инсталатери. На основу тих захтева дефинисан је модел корисничких профила и приступних права, који омогућава да се приступ систему ограничи по зонама и типу операције. Посебна пажња посвећена је правима `read`, `execute` и `manage`, јер она омогућавају раздвајање операција читања података, извршавања команди и управљања системом.

Решење је реализовано као проширење постојеће OBLO архитектуре, без нарушавања стандардног начина рада система. Сервис у облаку задужен је за управљање животним циклусом профила, ACL подацима и верификацијом приступа. Контролер користи синхронизоване податке о активном профилу и приступним правима приликом обраде захтева. Клијентска апликација приказује модел система и доступне функционалности у складу са активном подулогом, док MQTT комуникација преноси приступни контекст потребан за обраду команди и догађаја.

У програмском решењу дефинисани су модел података за корисничке профиле и ACL записе, REST API команде за управљање профилима, MQTT механизам за идентификацију активне подулоге, животни циклус профила и механизам синхронизације локалног стања. На тај начин је обезбеђено да се промене профила, зона, права или трајања приступа одразе на приказ система, MQTT претплате и обраду захтева на контролеру.

Тестирањем је потврђено да реализовани механизам подржава основне токове управљања профилима, укључујући креирање, ОТР верификацију, измену и брисање профила. Такође је потврђено да ограничење приступа по зонама утиче на приказ доступних ресурса и на пријем MQTT догађаја. Након измене ACL листе, MQTT претплате се ажурирају у складу са зонама које су додељене активном профилу.

Посебно значајан резултат тестирања односи се на проверу приступних права на контролеру. Тестови су показали да кориснички интерфејс није једини механизам заштите. Чак и када је у тестном окружењу омогућен покушај извршавања команде која није дозвољена активном профилу, контролер није извршио захтев ако ACL правила нису била испуњена. Овим је потврђено да се контрола приступа примењује у извршном слоју система, а не само кроз сакривање недоступних опција у апликацији.

Мерењем времена одзива проверен је утицај механизма подулога на синхронизацију локалног модела и извршавање команде SetServiceValueCmd. Добијени резултати показују да су просечна времена синхронизације у стандардном режиму и режиму са активном подулогом била приближна, при чему је измерена разлика износила -56 ms, односно -0,98%. Ова разлика представља нормалну варијацију мерења и не указује на суштинско убрзање или успорење система. Код извршавања команде SetServiceValueCmd измерено је повећање просечног времена са 220 ms на 240 ms, односно за 20 ms или 9,09%. На основу тога може се закључити да додатна обрада приступног контекста и ACL правила има мали и прихватљив утицај на време одзива и не нарушава очекиван рад система.

Главни допринос рада је у томе што је постојећи систем паметне куће проширен механизмом који омогућава финију контролу приступа. Уместо једноставног модела у ком корисник има потпун приступ или нема приступ, реализован је приступ у ком се права додељују према улози корисника, конкретном контролеру, зонама и типу операције. Такво решење је посебно значајно за инсталације у којима више корисника користи исти систем, али са различитим потребама и различитим нивоима овлашћења.

Ограничење рада је у томе што је решење анализирано у оквиру конкретне OBLO платформе и њене постојеће архитектуре. Због тога су модел података, комуникациони токови и начин примене приступних права прилагођени постојећим компонентама система. Ипак, принципи на којима је решење засновано, као што су везивање подулоге за конкретан контролер, примена ACL правила, ограничење по зонама и временски ограничен приступ, могу се применити и у другим системима паметне куће са сличном архитектуром.

Будући рад може обухватити детаљнију анализу перформанси у већем броју инсталација, проширење приступних правила на додатне типове ресурса, увођење напреднијих политика приступа и детаљније евидентирање активности корисника. Такође,

могуће је унапредити административне алате за управљање профилима и обезбедити додатне механизме за праћење промена приступних права током времена.

На основу реализованог решења и спроведеног тестирања може се закључити да механизам корисничких подулога испуњава постављене критеријуме. Решење омогућава контролисано, ограничено и временски условљено коришћење ресурса система паметне куће, уз очување компатибилности са постојећим начином рада OBLO система.

8. Литература

- [1] L. Atzori, A. Iera and G. Morabito, "The Internet of Things: A survey," *Computer Networks*, vol. 54, no. 15, pp. 2787–2805, 2010. doi: 10.1016/j.comnet.2010.05.010.
- [2] J. Gubbi, R. Buyya, S. Marusic and M. Palaniswami, "Internet of Things (IoT): A vision, architectural elements, and future directions," *Future Generation Computer Systems*, vol. 29, no. 7, pp. 1645–1660, 2013. doi: 10.1016/j.future.2013.01.010.
- [3] C. Wilson, T. Hargreaves and R. Hauxwell-Baldwin, "Smart homes and their users: a systematic analysis and key challenges," *Personal and Ubiquitous Computing*, vol. 19, no. 2, pp. 463–476, 2015. doi: 10.1007/s00779-014-0813-0.
- [4] A. J. B. Brush, B. Lee, R. Mahajan, S. Agarwal, S. Saroiu and C. Dixon, "Home Automation in the Wild: Challenges and Opportunities," *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*, pp. 2115–2124, 2011. doi: 10.1145/1978942.1979249.
- [5] M. Antić, I. Papp, S. Ivanović and M. Matić, "Learning From Smart Home Data: Methods and Challenges of Data Acquisition and Analysis in Smart Home Solutions," *IEEE Consumer Electronics Magazine*, vol. 9, no. 3, pp. 64–71, 2020. doi: 10.1109/MCE.2019.2955150.
- [6] M. Antić and I. Papp, "Smart Home Integration With External IoT Device Platforms and Services," *IEEE Consumer Electronics Magazine*, vol. 10, no. 6, pp. 69–75, 2021. doi: 10.1109/MCE.2020.3042008.
- [7] I. Krtolica, M. Antić and S. Ivanović, "A Solution for Management and Administration of Smart Home Systems," 2024 IEEE Zooming Innovation in Consumer Technologies Conference (ZINC), Novi Sad, Serbia, pp. 141–144, 2024. doi: 10.1109/ZINC61849.2024.10579308.
- [8] R. S. Sandhu, E. J. Coyne, H. L. Feinstein and C. E. Youman, "Role-Based Access Control Models," *Computer*, vol. 29, no. 2, pp. 38–47, 1996. doi: 10.1109/2.485845.
- [9] V. C. Hu, D. Ferraiolo, R. Kuhn, A. Schnitzer, K. Sandlin, R. Miller and K. Scarfone, *Guide to Attribute Based Access Control (ABAC) Definition and Considerations*, NIST Special Publication 800-162, National Institute of Standards and Technology, 2014. doi: 10.6028/NIST.SP.800-162.

-
- [10] A. Ouaddah, A. Abou Elkalam and A. Ait Ouahman, "Access control in the Internet of Things: Big challenges and new opportunities," *Computer Networks*, vol. 112, pp. 237–262, 2017. doi: 10.1016/j.comnet.2016.11.007.
- [11] W. He, M. Golla, R. Padhi, J. Ofek, M. Dürmuth, E. Fernandes and B. Ur, "Rethinking Access Control and Authentication for the Home Internet of Things (IoT)," *Proceedings of the 27th USENIX Security Symposium*, pp. 255–272, 2018.
- [12] S. Ameer, J. Benson and R. Sandhu, "The EGRBAC Model for Smart Home IoT," *2020 IEEE 21st International Conference on Information Reuse and Integration for Data Science*, pp. 457–462, 2020. doi: 10.1109/IRI49571.2020.00076.
- [13] S. Ameer, J. O. Benson and R. S. Sandhu, "An Attribute-Based Approach toward a Secured Smart-Home IoT Access Control and a Comparison with a Role-Based Approach," *Information*, vol. 13, no. 2, article 60, 2022. doi: 10.3390/info13020060.
- [14] R. T. Fielding, *Architectural Styles and the Design of Network-based Software Architectures*, Doctoral dissertation, University of California, Irvine, 2000.
- [15] R. Fielding, M. Nottingham and J. Reschke, *HTTP Semantics*, RFC 9110, Internet Engineering Task Force, 2022.
- [16] OASIS Open, *MQTT Version 5.0*, OASIS Standard, 2019.
- [17] M. Milosavljević, M. Matić, N. Jović and M. Antić, "Comparison of Message Queue Technologies for Highly Available Microservices in IoT," *Proceedings of the 65th ETRAN Conference*, RTI 2.6, 2021.
- [18] I. Papp, R. Pavlović and M. Antić, "WISE: MQTT-based Protocol for IP Device Provisioning and Abstraction in IoT Solutions," *Elektronika ir Elektrotechnika*, vol. 27, no. 2, pp. 86–95, 2021. doi: 10.5755/j02.eie.28826.